

AENOR

Esta obra está protegida por el derecho de autor y su reproducción y comunicación pública, en la modalidad puesta a disposición, se ha realizado en virtud de acuerdo suscrito entre AENOR y la UNIR. Queda prohibida su posterior reproducción, distribución, transformación y comunicación pública en cualquier medio y, de cualquier forma.

Tecnologías de la Información — Técnicas de Seguridad — Gestión de la Seguridad de la Información — Monitoreo, Medición, Análisis y Evaluación

*Tecnologías de la Información — Técnicas de Seguridad —
Gestión de la Seguridad de la Información — Monitoreo,
medición, analizar y evaluación*



Numero de Referencia
ISO/IEC 27004:2016(E)



DOCUMENTO PROTEGIDO POR DERECHO DE AUTOR

© ISO/IEC 2016, Publicado en Suiza

Todos los derechos reservados. A menos que se especifique lo contrario, ninguna parte de esta publicación podrá ser reproducida o utilizada de otra manera en cualquier forma o por cualquier medio, electrónico o mecánico, incluyendo fotocopias, o publicar en internet o en una intranet, sin permiso previo por escrito. Se puede solicitar permiso a ISO en la dirección siguiente o al órgano miembro de ISO en el país del solicitante.

Oficina de derechos de autor de ISO
Blandonnet Ch. 8 - CP 401
CH-1214 Vernier, Ginebra, Suiza
Tel. +41 22 749 01 11
Fax +41 22 749 0947
copyright@iso.org
www.iso.org

Prólogo.....	6
Introducción.....	7
1 Alcance.....	8
2 Referencias Normativas	8
3 Términos y definiciones	8
4 Estructura y Visión General	8
5 Razón Fundamental.....	10
5.1 La necesidad de medición.....	10
5.2 Cumplir con los requisitos ISO/IEC 27001	10
5.3 Validez de los resultados	10
5.4 Beneficios	11
6 Características	11
6.1 General.....	11
6.2 Qué controlar	12
6.3 Qué medir	13
6.4 ¿Cuándo monitorear, medir, analizar y evaluar?	14
6.5 ¿Quién controlará, medirá, analizará y evaluará?	15
7 tipos de medidas.....	15
7.1 General	15
7.2 Medidas de desempeño	16
7.3 Medidas de efectividad	17
8 Procesos.....	18
8.1 General.....	18
8.2 Identificar las necesidades de información	19
8.3 Crear y mantener medidas.....	20
8.3.1 General	20
8.3.2 Identificar las prácticas de seguridad actuales que pueden respaldar las necesidades de información	20
8.3.3 Desarrollar o actualizar medidas	21
8.3.4 Documentar medidas y priorizar para la implementación	23
8.3.5 Mantener a la gerencia informada y comprometida	23
8.4 Establecer procedimientos	23
8.5 Monitorear y medir.....	24
8.6 Resultados de los análisis.....	25
8.7 Evaluar el desempeño de seguridad de la información y la efectividad del SGSI	25
8.8 Revisar y mejorar los procesos de monitoreo, medición, análisis y evaluación	25
8.9 Retener y comunicar información documentada	25
Anexo A (informativo) Un modelo de medición de seguridad de la información.....	27
Anexo B (informativo) Ejemplos de construcciones de medición	29
Anexo C (informativo) Un ejemplo de construcción de medición de forma de texto libre.....	72
Bibliografía.....	73

Prólogo

ISO (La Organización Internacional de Normalización) y la IEC (La Comisión Electrónica Internacional) forman el sistema especializado para la estandarización mundial. Los organismos nacionales que son miembros de la ISO e IEC participan en el desarrollo de normas internacionales a través de comités técnicos establecidos por la organización respectiva para ocuparse de campos particulares de actividad técnica. Los comités técnicos ISO e IEC colaboran en campos de interés mutuo. Otras organizaciones internacionales, gubernamentales y no gubernamentales, en colaboración con ISO e IEC, también participan en el trabajo. En el campo de las tecnologías de la información, ISO e IEC han establecido un comité técnico conjunto, ISO/IEC JTC 1.

Los procedimientos utilizados para desarrollar este documento y los destinados a su posterior mantenimiento se describen en las Directivas ISO/IEC, Parte 1. En particular, deben tenerse en cuenta los diferentes criterios de aprobación necesarios para los diferentes tipos de documentos. Este documento fue redactado de acuerdo con las normas editoriales de las Directivas ISO/IEC, Parte 2 (ver www.iso.org/directives).

Se llama la atención sobre la posibilidad de que algunos de los elementos de este documento puedan estar sujetos a derechos de patente. ISO e IEC no serán responsables de identificar ninguno o todos los derechos de patente. Los detalles de los derechos de patente identificados durante la elaboración del documento se incluirán en la Introducción y/o en la lista ISO de declaraciones de patentes recibidas (ver www.iso.org/patents).

Cualquier nombre comercial utilizado en este documento es información dada para la comodidad de los usuarios y no constituye un respaldo.

Para obtener una explicación sobre el significado de los términos y expresiones específicos de ISO relacionados con la evaluación de la conformidad, así como información sobre la adhesión de ISO a los principios de la Organización Mundial del Comercio (OMC) en los Obstáculos Técnicos al Comercio (OTC), consulte la siguiente URL: www.iso.org/iso/foreword.html.

El comité responsable de este documento es ISO/IEC JTC 1, *Tecnología de la información*, Subcomité SC 27, *Técnicas de seguridad informática*.

Esta segunda edición de ISO/IEC 27004 cancela y sustituye a la primera edición (ISO/IEC 27004:2009), que ha sido revisada técnicamente.

Esta edición incluye los siguientes cambios significativos con respecto a la edición anterior. Una reestructuración total del documento porque tiene un nuevo propósito para proporcionar orientación sobre ISO/IEC 27001:2013, 9.1, que, en el momento de la edición anterior, no existió. Los conceptos y procesos han sido modificados y expandidos. Sin embargo, la base teórica (ISO/IEC 15939) sigue siendo la misma y varios de los ejemplos dados en la edición anterior se conservan, aunque actualizados.

Introducción

Este documento está destinado ayudar a las organizaciones a evaluar el desempeño de la seguridad de la información y la efectividad de un sistema de gestión de seguridad de la información para cumplir con los requisitos de ISO/IEC 27001:2013, 9.1: monitoreo, medición, análisis y evaluación.

Los resultados del monitoreo y la medición de un sistema de gestión de la seguridad de la información (SGSI) pueden respaldar las decisiones relacionadas con el gobierno, la gestión, la efectividad operativa y la mejora continua del SGSI.

Al igual que con otros documentos ISO/IEC 27000, este documento debe ser redactado, interpretado y adaptado a la situación específica de cada organización. Los conceptos y enfoques están destinados a ser ampliamente aplicables, pero las medidas particulares que requiere cualquier organización en particular dependen de factores contextuales (como el tamaño, sector, madurez, riesgos de seguridad de la información, obligaciones de cumplimiento y estilo de gestión) que varían ampliamente en la práctica.

Este documento se recomienda para las organizaciones que implementan un SGSI que cumpla con los requisitos de ISO/IEC 27001. Sin embargo, no establece ningún requisito nuevo para el SGSI que cumpla con ISO/IEC 27001 ni impone ninguna obligación a las organizaciones de observar las pautas presentadas.

Tecnología de la información — Técnicas de seguridad — Gestión de la seguridad de la información — Supervisión, medición, análisis y evaluación

1. Alcance

Este documento proporciona directrices destinadas a ayudar a las organizaciones a evaluar el rendimiento de la seguridad de la información y la eficacia de un sistema de gestión de la seguridad de la información con el fin de cumplir con los requisitos de ISO/IEC 27001:2013, 9.1. Establece:

- a) La supervisión y medición del rendimiento de la seguridad de la información;
- b) El seguimiento y medición de la eficacia de un sistema de gestión de la seguridad de la información (SGSI), incluidos sus procesos y controles;
- c) El análisis y evaluación de los resultados de la monitorización y medición.

Este documento es aplicable a todos los tipos y tamaños de organizaciones.

2. Referencias Normativas

En el texto se hace referencia a los siguientes documentos de forma que parte o la totalidad de su contenido constituya requisitos de este documento. En el caso de las referencias fechadas, sólo se aplica la edición citada. Para las referencias sin fecha, se aplica la última edición del documento al que se hace referencia (incluidas las enmiendas). No hay referencias normativas en este documento.

3. Términos y definiciones

A los efectos del presente documento, se aplicarán los términos y definiciones indicados en la norma ISO/IEC 27000.

ISO e IEC mantienen bases de datos terminológicas para su uso en estandarización en las siguientes direcciones:

- IEC Electropedia: disponible en <http://www.electropedia.org/>
- Plataforma de navegación ISO online: disponible en <http://www.iso.org/obp>

4. Estructurar una visión general

Este documento está estructurado de la siguiente manera:

- a) Justificación ([Cláusula 5](#));
- b) Características ([Cláusula 6](#));
- c) Tipos de medidas ([Cláusula 7](#));
- d) Procesos ([Cláusula 8](#)).

El orden de estas, está destinado a ayudar a la comprensión y el mapa los requisitos de ISO/IEC 27001:2013, 9.1 como se ilustra en la [Figure 1](#).

A partir de la información necesaria para cumplir con ese requisito, denominada necesidades de información, la organización determina las medidas que se utilizará para satisfacer sus necesidades de información. El proceso de seguimiento y medición produce datos que luego se analizan. Los resultados del análisis se evalúan en cumplimiento de las necesidades de información de la organización. Además, el [Anexo A](#) describe un modelo de medición para la seguridad de la información, incluida la relación entre los componentes del modelo de medición y los requisitos de ISO/IEC 27001:2013, 9.1.

En el [Anexo B](#) se ofrece una amplia gama de ejemplos. Estos ejemplos están destinados a proporcionar orientación práctica sobre cómo las organizaciones pueden monitorear, medir, analizar y evaluar sus procesos SGSI elegidos y áreas de rendimiento de la seguridad de la información. Estos ejemplos utilizan la plantilla sugerida que se indica en la [Tabla 1](#).

El [Anexo C](#) ofrece otro ejemplo utilizando un formato alternativo basado en texto de forma libre.

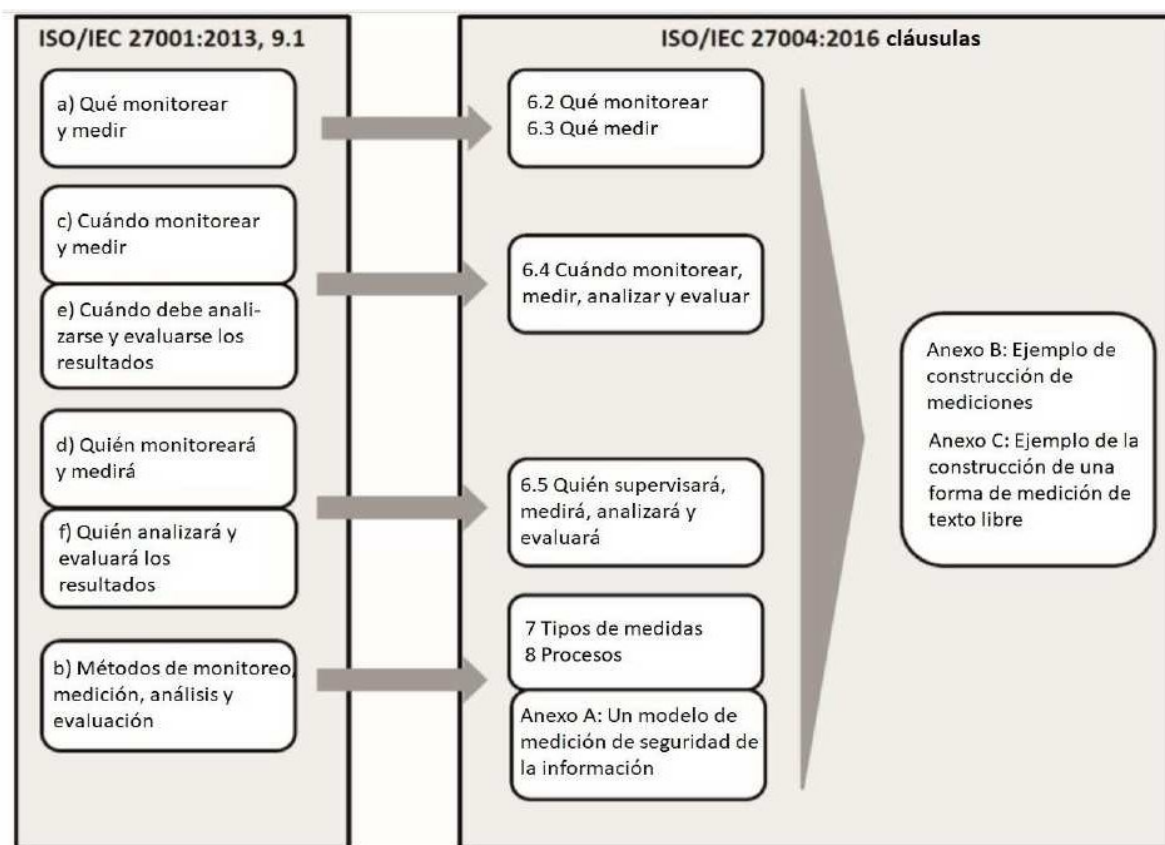


Figura 1 — Asignación a los requisitos ISO/IEC 27001:2013, 9.1

5. Razón Fundamental

5.1 La necesidad de medición

El objetivo general de un SGSI es la preservación de la confidencialidad, integridad y disponibilidad de información dentro de su ámbito de aplicación. Hay actividades del SGSI que se refieren a la planificación de cómo hacerlo, y la implementación de esos planes. Sin embargo, por sí solas, estas actividades no pueden garantizar que la realización de dichos planes cumpla los objetivos de seguridad de la información. Por lo tanto, en el SGSI definido por ISO/IEC 27001, existen varios requisitos para evaluar si los planes y actividades garantizan el cumplimiento de los objetivos de seguridad de la información.

5.2 Cumplir con los equilibrios ISO/IEC 27001

ISO/IEC 27001:2013, 9.1 requiere que la organización evalúe el rendimiento de la seguridad de la información y la eficacia SGSI. Los tipos de medidas que pueden cumplir estos requisitos se encuentran en la [Cláusula 7](#).

ISO/IEC 27001:2013, 9.1 requiere además que la organización determine:

- a) Lo que debe supervisar y medirse, incluidos los procesos y controles de seguridad de la información.
- b) Los métodos de seguimiento, medición, análisis y evaluación, según corresponda, para garantizar los resultados válidos;
- c) Cuando se realice el seguimiento y la medición;
- d) Que supervisará y tomará medidas;
- e) Cuando se analizan y evalúan los resultados de la supervisión y la medición; y
- f) Quien analizará y evaluará los resultados.

La asignación de estos requisitos se proporciona en la [Figura 1](#).

Por último, ISO/IEC 27001:2013, 9.1 requiere que la organización conserve la información documentada apropiada como evidencia de los resultados de monitoreo y medición (ver [8.9](#)).

ISO/IEC 27001:2013, 9.1 también señala que los métodos seleccionados deben producir resultados comparables y reproducibles para que se consideren válidos (ver [6.4](#)).

5.3 Validez de los resultados

ISO/IEC 27001:2013, 9.1 b) requiere que las organizaciones elijan métodos de medición, monitoreo, análisis y evaluación para garantizar resultados válidos. La cláusula señala que, para ser válidos, los resultados deben ser comparables y reproducibles. Para lograrlo, las organizaciones deben recopilar, analizar e informar de medidas, teniendo en cuenta los siguientes puntos:

- a) Con el fin de obtener resultados comparables en medidas que se basan en la supervisión en diferentes momentos, es importante garantizar que no se cambie el alcance y el contexto del SGSI;
- b) Los cambios en los métodos o técnicas utilizadas para la medición y el seguimiento no suelen dar lugar a resultados comparables. Con el fin de conservar la comparabilidad, pueden ser necesarias pruebas específicas como la aplicación paralela del original, así como los métodos modificados.

- c) Si los elementos subjetivos forman parte de los métodos o técnicas utilizados para la medición y el seguimiento, pueden ser necesarios pasos específicos para obtener resultados reproducibles. Como ejemplo, los resultados del cuestionario deben evaluarse con respecto a criterios definidos;
- d) En algunas situaciones, la reproductividad solo darse en circunstancias específicas. Por ejemplo, hay situaciones en las que los resultados no son resultados no son reproducibles, pero son válidos cuando se agregan.

5.4 Ventajas

Cumplir con los procesos y controles de SGSI y garantizar el rendimiento de la seguridad de la información puede proporcionar una serie de beneficios organizativos y financieros. Los principales beneficios pueden incluir:

- a) **Mayor responsabilidad:** Monitoreo, medición, análisis y evaluación puede aumentar la rendición de cuentas para la seguridad de la información ayudando a identificar procesos o controles específicos de seguridad de la información que se implementan incorrectamente, no se implementan o son ineficaces.
- b) **Mejora del rendimiento de la seguridad de la información y los procesos SGSI:** La supervisión, la medición, el análisis y la evaluación pueden permitir a las organizaciones cuantificar las mejoras en la protección de la información en el ámbito de su SGSI y demostrar un progreso cuantificable en el logro de los objetivos de seguridad de la información de la organización.
- c) **Evidencia de los requisitos de cumplimiento:** Monitoreo, medición, análisis y evaluación puede proporcionar evidencia documentada que ayude a demostrar el cumplimiento de ISO/IEC 27001 (y otros estándares), así como las leyes, normas y reglamentos aplicables.
- d) **Apoyar la toma de decisiones:** Monitoreo, medición, análisis y evaluación pueden apoyar el riesgo – toma de decisiones informada según la contribución de información cuantificable al proceso de gestión de riesgos. Pueden permitir que las organizaciones midan los éxitos y fracasos de las inversiones pasadas y actuales en seguridad de la información, y debe proporcionar datos cuantificables que puedan soportar las asignaciones de recursos para inversiones futuras.

6. Características

6.1 General

La supervisión y la medición es el primer paso de un proceso para evaluar el rendimiento de la seguridad de la información y la eficacia del SGSI.

Frente a una variedad potencialmente abrumadora de atributos de entidades relacionadas con la seguridad de la información que se pueden medir, no es del todo obvio cuáles deben medirse. Este es un tema importante porque es impracticable, costoso y contraproducente medir demasiados o atributos incorrectos. Aparte de los costos obvios de la medición, el análisis y la presentación de informes de numerosos atributos, aquí hay una clara posibilidad de que las cuestiones clave puedan ocultarse dentro de un gran volumen de información o se pierdan por completo si no existen medidas adecuadas.

Con el fin de determinar qué supervisar y medir, la organización debe considerar primero lo que desea lograr en la evaluación del rendimiento de la seguridad de la información y la eficacia SGSI. Esto puede permitirle determinar sus necesidades de información.

A continuación, las organizaciones deben decidir qué medidas son necesarias para apoyar cada necesidad de información discreta y qué se requiere para obtener las medidas necesarias. Por lo tanto, la medición siempre debe corresponder a las necesidades de información de la organización.

6.2 ¿Qué supervisar?

La supervisión determina el estado de un sistema, un proceso o una actividad para satisfacer una necesidad de información especificada.

Los sistemas, procesos y actividades que pueden ser monitoreados incluyen, pero no se limitan a:

- a) Implementación de los procesos SGSI;
- b) Gestión de incidentes;
- c) Gestión de vulnerabilidad;
- d) Gestión de la configuración;
- e) Concienciación y formación en seguridad;
- f) Acceso control, cortafuegos y otro registro de eventos;
- g) Auditoria;
- h) Proceso de evaluación de riesgos;
- i) Proceso de tratamiento de riesgos;
- j) Gestión de riesgos de terceros;
- k) Gestión de la continuidad del negocio;
- l) Gestión de la seguridad física y ambiental; y
- m) Supervisión del sistema.

Estas actividades de seguimiento producen datos (registros de eventos, entrevistas de usuarios, estadísticas de formación, información sobre incidentes, etc.) que se pueden utilizar para apoyar otras medidas. En el proceso de definición de los atributos a medir, se puede exigir una supervisión adicional para proporcionar información de apoyo.

Tenga en cuenta que la supervisión puede permitir a una organización determinar si un riesgo se ha materializado y, por lo tanto, indicar qué acción puede tomar para tratar dicho riesgo en sí mismo. Tenga en cuenta también que puede haber ciertos tipos de controles de seguridad de la información que tienen el propósito explícito de supervisar. Al utilizar los resultados de e dichos controles para apoyar la medición, las organizaciones deben asegurarse de que el proceso de medición tenga en cuenta si los datos utilizados se obtuvieron antes o después de cualquier acción de tratamiento.

6.3 ¿Qué medir?

La medición es una actividad realizada para determinar un valor, estado o tendencia en el rendimiento o la eficacia para ayudar a identificar las necesidades potenciales de mejora. La medición se puede aplicar a cualquier proceso SGSI, actividades, controles y grupos de controles.

Por ejemplo, considere ISO/IEC 27001:2013, 7.2 c), que requiere que una organización tome medidas, cuando proceda, para adquirir la competencia necesaria. Una organización puede determinar si todas las personas que requieren capacitación la han recibido y si la capacitación se ha impartido según lo planeado. Esto sepuede medir por el número o porcentaje de personas entrenada.

Una organización también determina si las personas que han sido capacitadas realmente adquirieron y conservaron la competencia necesaria que se puede medir con un cuestionario posterior a la formación.

Con respecto a los procesos SGSI, las organizaciones deben tener en cuenta que hay una serie de cláusulas en ISO/IEC 27001 que requiere explícitamente la eficacia de alguna actividad a determinar. Por ejemplo, ISO/IEC 27001:2013, 10.1 d) requiere que las organizaciones “revisen la eficacia de cualquier acción correctiva tomada”. Con el fin de llevar a cabo dicha revisión, la eficacia de las acciones correctivas debe determinarse en primer lugar en términos de alguna forma de medida definida. Para ello, las organizaciones deben definir primero una necesidad de información adecuada y una medida, o medidas para satisfacerla. El proceso para hacerlo se explica en la [Cláusula 8.](#)

Los procesos y actividades del SGSI que son candidatos para la medición incluyen:

- a) Planificación;
- b) Liderazgo;
- c) Gestión de riesgos;
- d) Gestión de políticas;
- e) Gestión de recursos;
- f) Comunicación;
- g) Revisión de la gestión;
- h) Documentación; y
- i) Auditoria.

Con respecto al rendimiento de la seguridad de la información, los candidatos más obvios son los controles de seguridad de la información de la organización o los grupos de dichos controles (o incluso el plan de tratamiento de riesgo). Estos controles se determinan mediante el proceso de tratamiento del riesgo y se denominan en la norma ISO/IEC 27001 como controles necesarios. Pueden ser ISO/IEC 27001:2013, controles del Anexo A, controles, sector-sectoriales (por ejemplo, definidos en la norma ISO/IEC 27010), controles especificados por otras normas y controles diseñados por la organización. Como el propósito de un control es modificar el riesgo, hay una variedad de atributos que se pueden medir, tales como:

- a) El grado en que un control reduce la probabilidad de que se produzca un evento;
- b) El grado en que un control reduce la consecuencia de un evento;
- c) La frecuencia de los eventos que un control puede hacer frente antes del fallo; y
- d) Cuanto tiempo después de la aparición de un evento toma para que el control detecte que el evento se ha producido.

6.4 ¿Cuándo monitorear, medir, analizar y evaluar?

Las organizaciones deben definir plazos específicos en los que supervisar, medir, analizar y evaluar, en función de las necesidades individuales de información, las garantías necesarias y el ciclo de vida de los datos que soportan medidas individuales. Las medidas de apoyo a los datos pueden recogerse con mayor frecuencia que el análisis y la presentación de informes de dichas medidas a las partes interesadas individuales. Por ejemplo, si bien los datos sobre incidentes de seguridad se pueden recopilar continuamente, la notificación de dichos datos a partes interesadas externas debe basarse en requisitos específicos, como la gravedad (posiblemente requiere notificación inmediata como en el caso de una infracción reportable) o valores agregados (como podría ser el caso de intentos de intrusión que se detectaron y bloquearon).

Las organizaciones deben tener en cuenta que, para satisfacer ciertas necesidades de información, antes de que puedan proceder al análisis y la evaluación, es necesario recopilar un volumen adecuado de datos para proporcionar una base significativa para la evaluación y la comparación (por ejemplo, al realizar análisis estadísticos). Además, los procesos de monitoreo, medición, análisis y evaluación pueden necesitar pruebas y ajustes antes de que las medidas resultantes puedan ser útiles para la organización. Por lo tanto, las organizaciones deben determinar un límite a la duración de cualquier ajuste fino (a fin de proceder con el objetivo real, la medición del SGSI) y durante cuánto tiempo debe continuar la supervisión y la recopilación antes de que pueda comenzar el análisis y la evaluación.

Las organizaciones pueden ajustar sus plazos de medición, ya que actualizan sus actividades de medición, para abordar los cambios ambientales específicos enumerados en [8.2](#). Por ejemplo, si una organización está pasando de un origen de datos manual a un origen automatizado, puede ser necesario un cambio en la frecuencia de recopilación. Además, se necesita una línea de base para comparar dos conjuntos de medidas adoptadas en diferentes momentos y potencialmente por métodos diferentes, pero con el objetivo de satisfacer la misma necesidad de información.

Una organización puede optar por estructurar sus actividades de monitoreo, medición, análisis y evaluación en un programa de medición. Sin embargo, es importante señalar que la NORMA ISO/IEC 27001 no tiene ningún requisito para que las organizaciones tengan un programa de este tipo.

6.5 ¿Quién supervisará, medirá, analizará y evaluará?

Las organizaciones (teniendo en cuenta los requisitos de ISO/IEC 27001:2013, 9.1 y [5.3](#)) deben especificar quién monitorea, mide, analiza y evalúa en términos de individuos o roles. La monitorización, la medición, el análisis y la evaluación se pueden realizar utilizando manuales o automatizados. Si la medición se realiza manual o automáticamente, las organizaciones pueden definir las siguientes funciones y responsabilidades relacionadas con la medición:

- a) Cliente de medición: la dirección u otras partes interesadas que soliciten o requieran información sobre la eficacia de un SGSI, controles o grupo de controles;
- b) Planificador de medición: la persona o unidad organizativa que define las construcciones de medición que vinculan atributos medibles a una necesidad de información especificada;
- c) Revisor de medición: la persona o unidad organizativa que valida que las construcciones de medición desarrolladas son adecuadas para evaluar el rendimiento de la seguridad de la información y la eficacia de un SGSI, controles o grupo de controles;
- d) Titular de la información: la persona o unidad organizativa propietaria de la información que proporciona información en las medidas. Esta persona es responsable de proporcionar los datos y también es responsable con frecuencia (pero no siempre) de realizar actividades de medición;
- e) Colector de información: la persona u unidad organizativa responsable de recopilar, registrar y almacenar los datos;
- f) Analista de información: la persona u unidad organizativa responsable de analizar los datos; y
- g) Comunicador de información: la persona u unidad organizativa responsable de comunicar los resultados del análisis.

Las organizaciones pueden combinar algunos, o posiblemente todos, de estos roles.

Las personas que desempeñan diferentes funciones y responsabilidades a lo largo de los procesos pueden requerir diversos conjuntos de habilidades y la conciencia y capacitación asociadas.

7. Tipos de medidas

7.1 General

A los efectos de esta orientación, el desempeño de las actividades planificadas y la eficacia de los resultados pueden medirse aplicando los dos tipos siguientes de medidas:

- a) Medidas de rendimiento: medidas que expresan los resultados previstos en términos de las características de la actividad planificada, tales como recuentos de cabezas, logros de hitos o el grado en que se han implementado los controles de seguridad de la información;

- b) medidas de eficacia: medidas que expresan el efecto que la realización de las actividades previstas tiene en los objetivos de seguridad de la información de la organización.

Estas medidas pueden ser intrínsecamente específicas de la organización, ya que cada organización tiene sus propios objetivos particulares de seguridad de la información, políticas y requisitos.

No es que los términos "medidas de rendimiento" y "medidas de eficacia" no deban confundirse con el requisito ISO/IEC 27001:2013, 9.1 para evaluar el rendimiento de la seguridad de la información y la eficacia del SGSI.

7.2 Medidas de rendimiento

Las medidas de rendimiento pueden ser usadas para demostrar el progreso en la implementación de procesos SGSI, procedimientos asociados y controles de seguridad específicos. Considerando que la eficacia se refiere a la medida en que se han realizado las actividades previstas y se han obtenido los resultados previstos, las medidas de rendimiento se refieren a la medida en que se han aplicado los procesos y controles de seguridad de la información. Estas medidas ayudan a determinar si los procesos SGSI y los controles de seguridad de la información se han implementado según lo especificado.

Las medidas de rendimiento utilizan datos que se puede obtener a partir de actas, registros de asistencia, planes de proyectos, herramientas de escaneo automatizado y otros medios de uso común de documentar, registrar y supervisar las actividades de SGSI.

La recopilación, el análisis y la notificación de medidas deben automatizarse siempre que sea posible, con el fin de reducir el coste y el esfuerzo requeridos y el potencial de error humano.

Ejemplo 1

Al medir el grado de implementación de los controles específicos de seguridad de la información, como el porcentaje de portátiles con cifrado de disco duro, los resultados de esta medida probablemente serán, al principio, inferiores al 100%. Cuando el resultado alcanza y se mantiene al 100%, se puede concluir que los sistemas de información han implementado plenamente los controles de seguridad abordados por esta medida, y las actividades de medición pueden reenfocarse en otros controles que necesitan mejoras.

Ejemplo 2

Para un nuevo SGSI, la organización primero debe procurar asegurarse de que la alta dirección asista a la revisión y otras reuniones que se pueden llamar. El resultado planificado (o previsto) es la plena asistencia a todas las reuniones, salvo enfermedad y compromisos previos permitidos. La medida es simplemente cuántos asisten frente a cuántos deben asistir, con un posible modificador que la ausencia fue por una buena razón. En un primer momento, los resultados de las medidas se podrían indicar un déficit. Sin embargo, con el tiempo, los resultados deben alcanzar y permanecer cerca de sus objetivos planificados. En este punto, la organización debe comenzar a centrar sus esfuerzos de medición en medidas de eficacia (ver [7.3](#))

Después de que la mayoría de las medidas de rendimiento alcancen y permanezcan al 100%, la organización debe comenzar a centrar sus esfuerzos de medición en las medidas de eficacia. Las organizaciones nunca deben retirar completamente las medidas de rendimiento porque pueden ser útiles para señalar controles de seguridad específicos que necesitan mejoras; sin embargo, con el tiempo, el énfasis y los recursos que se aplican a la medición deben alejarse de estas medidas y hacia medidas de eficacia (ver [7.3](#)).

Según ISO/IEC 27001:2013, 9.1, también es importante medir también la eficacia del sistema de gestión (discutido a continuación). Para operar un SGSI adecuado, las organizaciones deben medir la por formación y eficacia a intervalos planificados.

7.3 Medidas de eficacia

Deben utilizarse medidas de eficacia para describir la eficacia y el impacto que las realizaciones del plan de tratamiento de riesgos SGSI y los procesos y controles del SGSI tienen en los objetivos de seguridad de la información de la organización. Estas medidas deben utilizarse para determinar si los procesos del SGSI y los controles de seguridad de la información funcionan según lo previsto y logran los resultados deseados. Dependiendo de esos objetivos, la eficacia se puede utilizar para cuantificar, por ejemplo:

- a) Ahorros de costos producidos por el SGSI o a través de los costos incurridos por abordar incidentes de seguridad de la información;
- b) el grado de confianza del cliente ganado/mantenido por el SGSI; y
- c) el logro de otros objetivos de seguridad de la información.

Las medidas de eficacia se pueden crear combinando los datos obtenidos de herramientas automatizadas de supervisión y evaluación con datos derivados manualmente sobre la actividad del SGSI. Esto puede requerir el seguimiento de una variedad de medidas en toda la organización de una manera que se puede vincular directamente a las actividades de SGSI y eventos de seguridad de la información. Para lograr esto, una organización debe tener una capacidad establecida para:

- d) Evaluar el grado en que los procesos SGSI, controles o grupos de controles han sido imprecisos a través de medidas de rendimiento;
- e) Recopilar datos de herramientas automatizadas de monitoreo y evaluación;
- f) Recopilar manualmente datos de las actividades del SGSI;
- g) normalizar y analizar los datos procedentes de múltiples fuentes automatizadas y manuales; y
- h) interpretar e informar de estos datos a los responsables de la toma de decisiones.

Estas medidas de eficacia combinan información sobre la realización del plan de tratamiento de riesgos con una variedad de información sobre los recursos y pueden proporcionar insumos para el proceso de gestión de riesgos. También pueden proporcionar la visión más directa del valor de la seguridad de la información para la organización y pueden ser los que deberían ser de mayor interés para la alta dirección.

Ejemplo 3

Se sabe que las explotaciones de vulnerabilidad conocidas causan una gran parte de los incidentes de seguridad de la información. Cuanto mayor sea el número de vulnerabilidad conocidas y cuanto más tiempo no se aborden (por ejemplo, parcheado), mayor será la exposición al riesgo relacionada. Una medida efectiva puede ayudar a una organización a determinar su exposición al riesgo causada por este tipo de vulnerabilidades.

Ejemplo 4

Un curso de formación puede tener objetivos de formación específicos para cada módulo del curso. Una medida de efectividad puede ayudar a la organización a determinar en qué medida cada alumno ha extendido cada lección y puede aplicar sus nuevos conocimientos y habilidades. Estas medidas generalmente requieren múltiples puntos de datos, tales como: resultados de pruebas posteriores al entrenamiento; examen de datos de incidentes correlacionados con temas de capacitación; o análisis de llamadas a la mesa de ayuda correlacionadas con temas de capacitación.

8. Procesos

8.1 General

El monitoreo, medición, análisis y evaluación (ver [Figura 2](#)) consta de los siguientes procesos: logran los resultados deseados. Dependiendo de esos objetivos, la eficacia se puede utilizar para cuantificar, por ejemplo:

- a) Identificar las necesidades
- b) Crear y mantener medidas
- c) Establecer procedimientos
- d) Monitorear y medir
- e) Analizar los resultados; y
- f) Evaluar el desempeño de la seguridad de la información y la efectividad del SGSI.

Además, hay un proceso de gestión del SGSI que cubre la revisión y mejora de los procesos anteriores, ver [8.8](#).

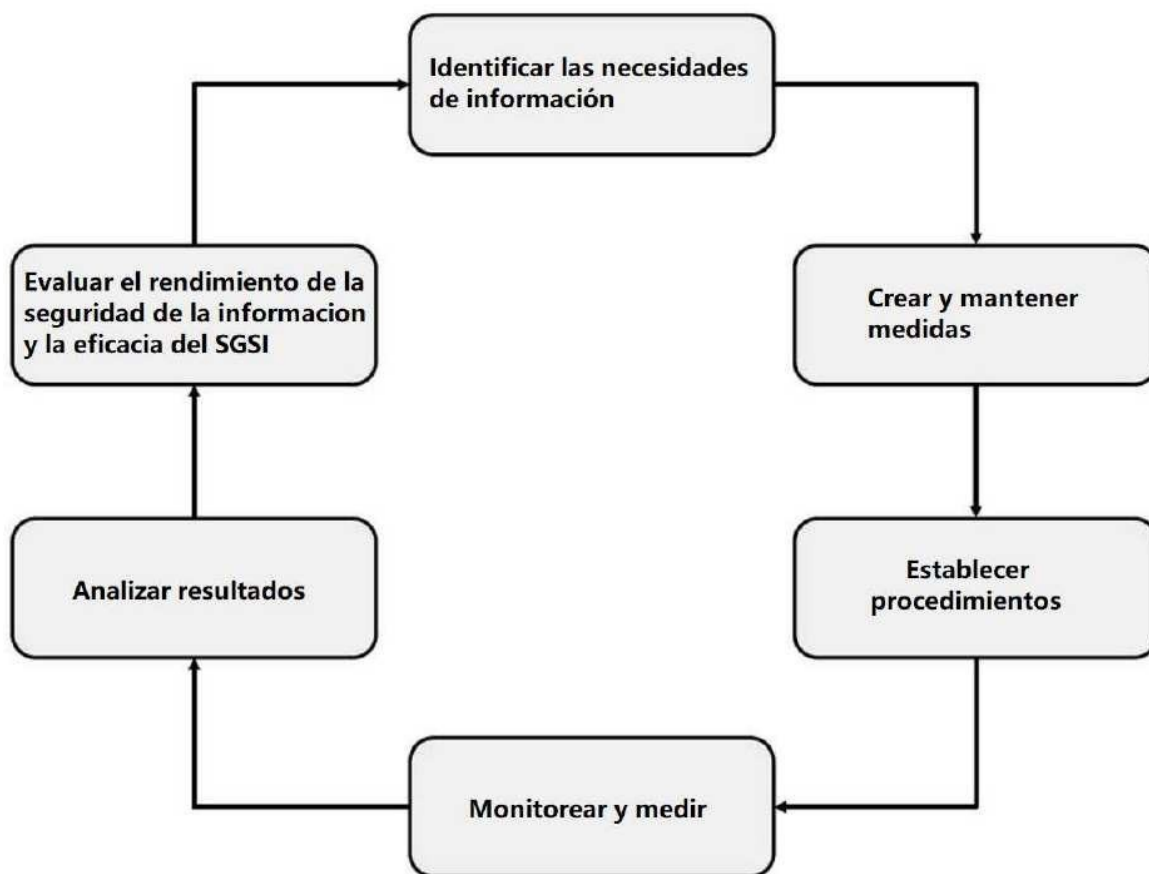


Figura 2 - Procesos de monitoreo, medición, análisis y evaluación.

8.2 Identificar las necesidades de información

La creación de medidas debe comenzar con la identificación de las necesidades de información, que pueden ayudar a comprender las características operativas y/o el desempeño de cualquier aspecto del SGSI, como cualquiera de los siguientes:

- a) Necesidades de la parte interesada;
- b) La dirección estratégica de la organización;
- c) Política y objetivos de seguridad de la información; y
- d) El plan de tratamiento de riesgo.

Se debe realizar las siguientes actividades para identificar las necesidades de información relevantes:

- e) Examinar el SGSI, sus procesos y otros elementos como:
 - 1) Política y objetivos de seguridad de la información, objetivos y controles;
 - 2) Requisitos legales, reglamentarios, contractuales y organizativos para la seguridad de información; y
 - 3) Los resultados del proceso de gestión de riesgos de seguridad de la información.

- f) Priorizar las necesidades de información identificadas en función de criterios, tales como:
 - 1) Prioridades de tratamiento de riesgos;
 - 2) Capacidades y recursos de una organización;
 - 3) Necesidades de las partes interesadas;
 - 4) La política y los objetivos de seguridad de la información y los objetivos de control;
 - 5) Información requerida para cumplir con las obligaciones organizacionales, legales, reglamentarias y contractuales; y
 - 6) El valor de la información a obtener en relación con el costo de medición.
- g) Seleccionar un subconjunto de necesidades de información que deben abordarse en las actividades de medición de la lista priorizada; y
- h) Documentar y comunicar las necesidades de información seleccionada a todas las partes interesadas relevantes.

8.3 Crear mantener medidas

8.3.1 General

Las organizaciones deberían crear medidas de una vez en adelante y revisarlas y actualizarlas sistemáticamente a intervalos planificados o cuando el entorno del SGSI sufra cambios sustanciales. Dichos cambios pueden incluir, entre otros:

- a) El alcance del SGSI;
- b) Estructura organizativa;
- c) Partes interesadas, incluidos los roles, responsabilidades y autoridades de las partes interesadas;
- d) Objetivos y requisitos comerciales;
- e) Requisitos legales y reglamentarios;
- f) Logro de resultados deseados y estables para varios ciclos posteriores; y
- g) Introducción o disposición de tecnologías y sistemas de procesamiento de la información.

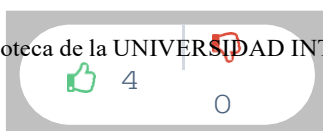
crear o actualizar tales medidas puede incluir, entre otros, los siguientes pasos:

- h) Identificar las prácticas de seguridad actuales que pueden respaldar las necesidades de información;
- i) Desarrollar o actualizar medidas;
- j) Documentar medidas y definir la prioridad de implementación; y
- k) Mantener a la gerencia informada y comprometida.

Se espera que la actualización de las medidas tome menos tiempo y esfuerzo que la creación inicial.

8.3.2 Identificar las prácticas de seguridad actuales que pueden respaldar las necesidades de información

Una vez que se identifica una necesidad de información, las organizaciones deben inventariar las medidas de medición y prácticas de seguridad existentes como un componente potencial de la medición. Las prácticas de medición y seguridad pueden incluir mediciones asociadas con:



- a) Gestión de riesgos;
- b) Gestión de proyectos;
- c) Informes de cumplimiento; y
- d) Políticas de seguridad.

8.3.3 Desarrollar o actualizar medidas

Las medidas deben responder a la necesidad de información. Pueden confiar en las prácticas actuales o necesitan otras nuevas. Las medidas recientemente identificadas también pueden implicar una adaptación de medidas existentes o procesos de medición. En cualquier caso, las medidas identificadas deben definirse con suficiente detalle para permitir su implementación.

Los ejemplos de datos que se pueden recopilar para respaldar las medidas de seguridad incluyen:

- a) salida de varios registros y escaneos;
- b) estadísticas sobre capacitación y otras actividades de recursos humanos;
- c) encuestas y cuestionarios relevantes;
- d) estadísticas de incidentes;
- e) resultados de auditorías internas;
- f) resultados de la continuidad del negocio / ejercicios de recuperación ante desastres; y
- g) informes de revisiones de la gerencia.

Deben examinarse estas y otras posibles fuentes de datos, que pueden ser de origen interno o externo, y deben identificarse los tipos de datos disponibles.

Las medidas seleccionadas deben apoyar la prioridad de las necesidades de información y pueden considerar:

- h) facilidad de recopilación de datos;
- i) disponibilidad de recursos humanos para recopilar y gestionar datos;
- j) disponibilidad de herramientas apropiadas;
- k) número de indicadores de desempeño potencialmente relevantes respaldados por la medida;
- l) facilidad de interpretación;
- m) número de usuarios de resultados de medición desarrollados;
- n) evidencia que muestre la idoneidad de la medida para el propósito o la necesidad de información; y
- o) costos de recopilación, gestión y análisis de los datos.

Las organizaciones deben documentar cada medida en una forma que vincule la medida con la necesidad (o necesidades) de información relevante y proporcione información suficiente sobre las características que describen la medida y cómo recopilarla, analizarla e informarla. Los descriptores de información sugeridos se proporcionan en la Tabla 1.

Los ejemplos en el Anexo B usan la Tabla 1 como plantilla. Dos ejemplos tienen un descriptor de información adicional (llamado "acción"), que define la acción a tomar en caso de que no se cumpla el objetivo. Las organizaciones pueden incluir este descriptor de información si lo consideran útil. No existe una única forma de especificar tales construcciones de medición y el Anexo C demuestra un enfoque alternativo de forma libre.



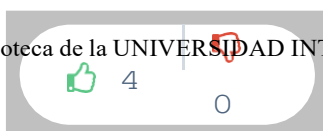
Cabe señalar que es posible que se deban proporcionar diferentes medidas para satisfacer las necesidades de diferentes clientes de medición (ver Tabla 1), que pueden ser internas o externas. Por ejemplo, las medidas para abordar las necesidades de información de la alta gerencia pueden diferir de aquellas para el consumo del administrador del sistema (por ejemplo, cualquiera de las partes interesadas puede tener un rango o enfoque específico o granularidad).

Cada medida debe corresponder, al menos, a una necesidad de información, mientras que una sola necesidad de información puede requerir varias medidas.

Las organizaciones deben tener cuidado al usar medidas subjetivas, ya que las medidas formadas mediante la combinación de dos o más medidas subjetivas pueden afectar negativamente el resultado final.

Tabla 1 - Ejemplos de descriptores de medidas de seguridad

Información descriptora	Significado o propósito
ID de medida	Identificador específico.
Necesidad de información	Necesidad general de comprender a qué contribuye la medida.
Medida	Declaración de medición, generalmente descrita usando una palabra como "porcentaje", "Número", "frecuencia" y "promedio".
Fórmula/puntuación	Cómo se debe evaluar, calcular o puntuar la medida.
Objetivo	Resultado deseado de la medición, por ejemplo, un hito o una medida estadística o un conjunto de umbrales. Tenga en cuenta que se puede requerir un monitoreo continuo para asegurar el logro continuo del
Implementación evidencia	La evidencia que valida que la medición se realiza, ayuda a identificar posibles causas de malos resultados y proporciona información para el proceso. Datos para proporcionar entrada en la fórmula.
Frecuencia	Con qué frecuencia se deben recopilar e informar los datos. Puede haber una razón para tener múltiples frecuencias.
Partes responsables	La persona responsable de recopilar y procesar la medida. Como mínimo, se debe identificar un propietario de la información, un recopilador de información y un cliente de medición.
Fuente de datos	Las fuentes de datos potenciales pueden ser bases de datos, herramientas de seguimiento, otras partes de la organización, organizaciones externas o roles individuales específicos.
Informes formato	Cómo se debe recopilar e informar la medida, por ejemplo, como texto, numéricamente, gráficamente (gráfico circular, gráfico de líneas, gráfico de barras, etc.), como parte de un "tablero" u otra forma de presentación.



Es muy importante definir medidas de tal manera que se recopilen datos una vez y se utilicen para múltiples propósitos. Idealmente, los mismos datos deberían respaldar una variedad de medidas que pueden responder a las necesidades de información de diferentes partes interesadas. Tenga en cuenta también que lo que es más fácil de medir no necesita ser más significativo o más relevante.

Los objetivos deben indicar los estados finales deseados para medidas específicas con respecto a los procesos y controles del SGSI, el logro de los objetivos de seguridad de la información y para evaluar la efectividad del SGSI.

El establecimiento de objetivos puede facilitarse si se dispone de datos históricos relacionados con medidas desarrolladas o seleccionadas. Las tendencias observadas en el pasado pueden en algunos casos proporcionar información sobre los rangos de rendimiento que han existido anteriormente y guiar la creación de objetivos realistas. Sin embargo, se debe advertir a las organizaciones que, sin la debida consideración, establecer objetivos basados en lo que se logró previamente.

8.3.4 Documentar medidas y priorizar para la implementación

Después de la definición de las medidas requeridas, su compilación debe documentarse y priorizarse para su implementación en función de la prioridad de cada necesidad de información y la viabilidad de obtener los datos. Las medidas de rendimiento deben implementarse primero para garantizar que se hayan implementado los procesos y controles del SGSI. Una vez que las medidas de rendimiento producen valores específicos, también se pueden implementar medidas de efectividad. Consulte también 6.4 para obtener orientación sobre cuándo realizar el monitoreo y las actividades relacionadas.

8.3.5 Mantenga a la gerencia informada y comprometida

La gerencia en diferentes niveles organizacionales necesita involucrarse en el desarrollo e implementación de medidas, de modo que las medidas reflejen las necesidades de la gerencia. Además, la gerencia debe recibir actualizaciones periódicas en formatos y estilos apropiados, para garantizar que se mantenga informado sobre las actividades de medición de seguridad durante todo el proceso de desarrollo, implementación y aplicación de medidas.

8.4 Establecer procedimientos

Para implementar medidas definidas y priorizadas, se deben seguir los siguientes pasos:

- a) Las partes interesadas que deberían participar en el proceso de medición de seguridad deben ser informadas de las actividades de medición y la justificación de la misma; y
- b) Las herramientas de recopilación y análisis de datos deben identificarse y, si es necesario, modificarse, para reunir medidas de manera efectiva y eficiente.

Las organizaciones deben establecer procedimientos para la recopilación de datos, análisis e informes de medidas, por ejemplo:

- c) Recopilación de datos, incluido el almacenamiento seguro de datos y la verificación. Los procedimientos deben definir cómo se recopilan, almacenan, verifican los datos y qué información de contexto es necesaria para su posterior procesamiento. La verificación de datos se puede realizar aplicando técnicas tales como:

- 1) Garantizar que un valor se encuentre dentro de un rango de valores posibles;
 - 2) Comparar con una lista de valores esperados; y
 - 3) Capturar información contextual, por ejemplo, el momento en que se recopiló un dato.
- d) Análisis de datos e informes de análisis de medidas. Los procedimientos deben especificar las técnicas de análisis de datos y la frecuencia para informar las medidas resultantes;
- e) Métodos y formatos de informes, que pueden incluir:
- 1) Cuadros de mando para proporcionar información estratégica mediante la integración de indicadores de desempeño de alto nivel;

Nota: Estos pueden denominarse "indicadores clave de rendimiento" (consulte el modelo de medición de seguridad de la información en el Anexo A).

- 2) cuadros de mando ejecutivos y operativos centrados en objetivos estratégicos, en lugar de controles y procesos específicos;
- 3) formatos de informes que van desde estilos simples y estáticos, como una lista de medidas para un período de tiempo determinado, hasta informes de referencias cruzadas más sofisticados con agrupaciones anidadas, resúmenes continuos y análisis o enlaces dinámicos. Los informes pueden ser más útiles cuando es necesario presentar a las partes interesadas datos sin procesar en un formato fácil de leer; y
- 4) indicadores para representar valores dinámicos que incluyen alertas, elementos gráficos adicionales y etiquetado de puntos finales.

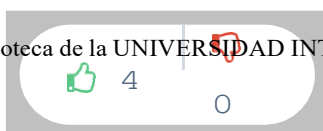
8.5 Monitorear y medir

Deben definirse los procedimientos para el monitoreo y la medición realizados por medios manuales o automáticos, y para el almacenamiento y la verificación. La verificación de datos se puede realizar al calificar los datos recopilados en una lista de verificación para garantizar que los efectos en el análisis de los datos faltantes sean mínimos y que los valores sean correctos o estén dentro de los límites reconocidos. Con el fin de analizar, se deben recopilar datos suficientes para garantizar que los resultados del análisis sean confiables.

Las organizaciones deben recopilar, analizar, evaluar e informar medidas a las partes interesadas relevantes con una periodicidad establecida. Cuando ocurre cualquiera de las condiciones establecidas en 8.3.1, la organización debería considerar actualizar sus procesos de monitoreo, medición, análisis y evaluación.

Antes de publicar información en informes, paneles, etc., la organización debe determinar cómo se pueden compartir los datos y resultados recopilados y con quién, ya que algunos datos relacionados con la seguridad de la información pueden ser sensibles desde una perspectiva de confidencialidad.

Además, es beneficioso tener un proceso para verificar y evaluar el proceso de recolección para confirmar que se están recolectando las medidas correctas y de manera tal que sean repetibles, precisas y consistentes.



8.6 Analizar resultados

Los datos recopilados deben analizarse en relación con el objetivo para cada medida individual. La orientación para realizar análisis estadísticos se puede encontrar en ISO / TR 10017.

Los resultados del análisis de datos deben ser interpretados. La persona que analiza los resultados (comunicador) debería poder sacar algunas conclusiones iniciales basadas en los resultados. Sin embargo, dado que los comunicadores pueden no estar directamente involucrados en los procesos técnicos y de gestión, tales conclusiones deben ser revisadas por otras partes interesadas. Todas las interpretaciones deben tener en cuenta el contexto de las medidas.

El análisis de datos debe identificar brechas entre los resultados de medición esperados y reales de un SGSI implementado, controles o grupos de controles. Las brechas identificadas pueden señalar las necesidades para mejorar el SGSI implementado, incluido su alcance, políticas, objetivos, controles, procesos y procedimientos.

8.7 Evaluar el desempeño de seguridad de la información y la efectividad del SGSI

De acuerdo con el [5.2](#), las organizaciones deberían:

- a) Expresar sus necesidades de información en términos de las preguntas de la organización con respecto al desempeño de la seguridad de la información y la efectividad del SGSI; y
- b) Expresan sus medidas en términos de esas necesidades de información.

Por lo tanto, se deduce que el análisis de los resultados del monitoreo y la medición proporcionarán datos que se pueden utilizar para satisfacer las necesidades de información (ver Anexo A). La evaluación es el proceso de interpretar esos datos para responder al desempeño de seguridad de la información de la organización y las preguntas de efectividad del SGSI.

8.8 Revisar y mejorar los procesos de monitoreo, medición, análisis y evaluación

Los procesos de monitoreo, medición, análisis y evaluación deben mejorar continuamente con las necesidades del SGSI. Las actividades de mejora continua pueden incluir, entre otras cosas:

- a) Solicitar comentarios de las partes interesadas;
- b) Revisar las técnicas de recolección y análisis, basadas en las lecciones aprendidas y otros comentarios;
- c) Revisar los procedimientos de implementación; y
- d) Datos de evaluación comparativa de seguridad de la información.

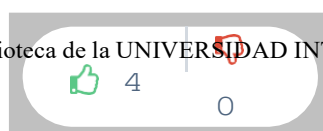
8.9 Retener y comunicar información documentada

Para cumplir con los requisitos de ISO / IEC 27001: 2013, 9.1, solo es necesario que las organizaciones retengan información documentada como evidencia del monitoreo y las mediciones de la organización. Las organizaciones tienen libertad para decidir qué es lo apropiado. Las organizaciones pueden, por ejemplo, documentar el proceso y los métodos utilizados para analizar y evaluar los resultados.

Los informes que se utilizan para comunicar los resultados de las mediciones a las partes interesadas relevantes deben prepararse utilizando los formatos de informes apropiados. Las conclusiones del análisis deben ser revisadas por las partes interesadas relevantes para garantizar una interpretación adecuada de los datos. Los resultados del análisis de datos deben documentarse para la comunicación a las partes interesadas.

El comunicador de información debe determinar cómo comunicar los resultados de medición de seguridad de la información, tales como:

- a) Qué resultados de la medición deben informarse interna y externamente;
- b) Listados de medidas correspondientes a partes interesadas individuales y partes interesadas;
- c) Resultados de medición específicos que se proporcionarán, y el tipo de presentación, adaptado a las necesidades de cada grupo; y
- d) Medios para obtener comentarios de las partes interesadas que se utilizarán para evaluar la utilidad de los resultados de medición y la efectividad de la medición de seguridad de la información.



Anexo A (informativo)

Un modelo de medición de seguridad de la información

El modelo de información de medición descrito en Figura [Figura A.1](#) se presenta y explica en ISO / IEC 15939, y se puede aplicar a SGSI. Describe El modelo de información de medición descrito en [Figura A.1](#) se presenta y explica en ISO / IEC 15939, y se puede aplicar a SGSI. Describe El modelo de información de medición descrito en [Figura A.1](#) se presenta y explica en ISO / IEC 15939, y se puede aplicar a SGSI. Describe cómo los atributos de las entidades relevantes pueden cuantificarse y convertirse en indicadores que proporcionan una base para la toma de decisiones. El modelo es una estructura que comienza con la vinculación de las necesidades de información con las entidades relevantes y los atributos de interés. Por ejemplo, la necesidad de información puede ser qué tan bien están informados los empleados sobre la política de seguridad de la información. Las entidades incluyen procesos, controles, información documentada, sistemas, dispositivos, personal y recursos. Ejemplos de entidades relevantes en un SGSI son: proceso de gestión de riesgos, proceso de auditoría, clasificación de información, gestión de derechos de acceso, política de seguridad de la información, política de dispositivos móviles, computadora de back-end, administrador y empleado.

El modelo de información de medición ayuda a determinar lo que el planificador de medición necesita especificar durante el monitoreo, medición, análisis y evaluación.

ISO / IEC 27001: 2013, 9.1 requiere que las organizaciones evalúen el desempeño de la seguridad de la información y la efectividad del SGSI. Esto a menudo implica la identificación de indicadores, y a partir de estos, de acuerdo con el significado y la importancia de los indicadores para los propósitos de la organización, se pueden identificar indicadores clave de rendimiento (KPI, a veces también denominados "indicadores clave de éxito"). Para determinar tales indicadores, una organización puede establecer medidas de base y derivar una medida de ellos mediante el uso de una función de medición que combina dos o más medidas de base. El modelo de medición en este Anexo (usando la medida base, la medida derivada, el indicador de desempeño y el resultado de la medición) es un ejemplo del enfoque para cumplir con los requisitos del SGSI para la medición. Hay otras formas posibles de ver el proceso de medición.



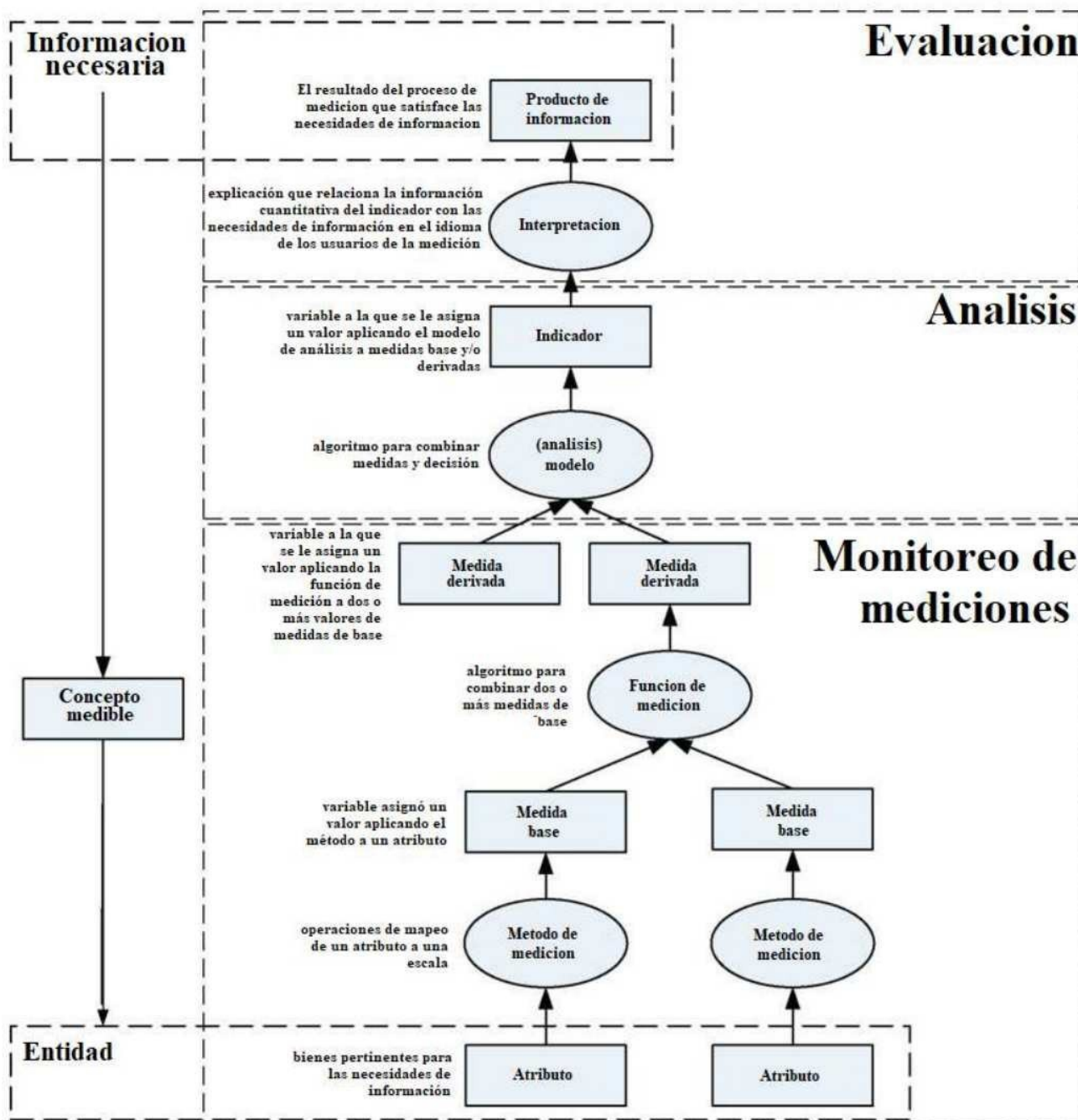


Figura A.1 – Relaciones clave en el modelo de información de medición

Anexo B (informativo)

Ejemplos de construcción de medidas

B.1 General

Los ejemplos del Anexo B siguen los principios establecidos en este documento. La tabla siguiente asigna ejemplos de construcción de medida a cláusulas específicas o números de objetivos de control en ISO/IEC 27001:2013.

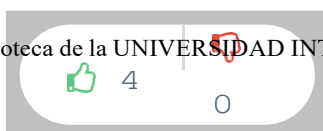
Procesos y controles relacionados con el SGSI (Cláusula o número de control en ISO/IEC 27001:2013)	Nombres de ejemplo de construcción de medida
5.1, 7.1	B.2 Asignación de recursos
7.5.2, A.5.1.2	B.3 Revisión de políticas
5.1, 9.3	B.4 Compromiso de gestión
8.2, 8.3	B.5 Exposición al riesgo
9.2, A.18.2.1	B.6 Programa de auditoría
10	B.7 Acciones de mejora
10	B.8 Costos de incidentes de seguridad
10, A.16.1.6	B.9 Incidentes de seguridad de la información del formulario de aprendizaje
10.1	B.10 Implementación de la acción correctiva
A.7.2	B.11 SGSI o concienciación SGSI
A.7.2.2	B.12 Capacitación en seguridad de la información
A.7.2.1, A.7.2.2	B.13 Cumplimiento de concienciación sobre la seguridad de la información
A.7.2.2	B.14 Eficacia de las campañas de concienciación del SGSI
A.7.2.2, A.9.3.1, A.16.1	B.15 Preparación de la ingeniería social
A.9.3.1	B.16 Calidad de contraseña - manual
A.9.3.1	B.17 Calidad de contraseña - automatizada
A.9.2.5	B.18 Revisión de los derechos de acceso de los usuarios
A.11.1.2	B.19 Evaluación del sistema de controles de entrada física
A.11.1.2	B.20 La entrada física controla la eficacia
A.11.2.4	B.21 Gestión del mantenimiento periódico
A.12.1.2	B.22 Gestión del cambio
A.12.2.1	B.23 Protección contra código malicioso
A.12.2.1	B.24 Anti-malware
A.12.2.1, A.17.2.1	B.25 Disponibilidad total
A.12.2.1, A.13.1.3	B.26 Reglas de cortafuego B.26
A.12.4.1	B.27 Revisión de archivos de registro
A.12.6.1	B.28 Configuración del dispositivo
A.12.6.1, A.18.2.3	B.29 Pentest y evaluación de vulnerabilidades
A.12.6.1	B.30 Paisaje de vulnerabilidad
A.15.1.2	B.31.1/B.31.2 Seguridad en acuerdos de terceros

Procesos y controles SGSI relacionados (Cláusula o número de control en ISO/IEC 27001:2013)	Nombres de ejemplo de construcción de medida
A.16	B.32 Eficacia en la gestión de incidentes de
A.16.1	B.33 Tendencia de incidentes de seguridad
A.16.1.3	B.34 Informes de eventos de seguridad
A.18.2.1	B.35 Proceso de revisión de SGSI
A.18.2.3	B.36 Cobertura de vulnerabilidad

Para cada ejemplo se incluye una referencia cruzada de la relación con cláusulas o números de objetivos de control en ISO/IEC 27001:2013. Además, para dos ejemplos ([B.20](#) y [B.28](#)) se incluye un descriptor de información adicional llamado "acción". Esto define la acción que se debe realizar en caso de que no se cumpla el destino. Las organizaciones pueden incluir este descriptor de información si lo consideran útil. De hecho, no existe una única manera de especificar esas construcciones de medición y el [Anexo C](#) demuestra un enfoque alternativo de forma libre.

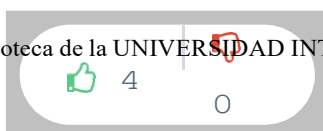
B.2 Asignación de recursos

Descriptor de información	Significado o propósito
ID de medida	Definido por la organización
Necesidad de información	Cuantificar los recursos que se asignan a la seguridad de la información con respecto a los presupuestos originales
Medida	Desglose de los recursos asignados a la seguridad de la información (personal interno, personal contratado, hardware, software, servicios) dentro del presupuesto anual
Fórmula/puntuación	Recursos asignados/recursos usados dentro de un período de tiempo presupuestado
Objetivo	I
Evidencia de implementación	Supervisión de recursos de seguridad de la información
Frecuencia	Anual
Partes responsables	Propietario de la información: administrador de seguridad de la información Recopilador de información: gestor de seguridad de la información Información Cliente: consejo de administración
Fuente de datos	Presupuesto de seguridad de la información Gasto efectivo en seguridad de la información Informes de uso de recursos de seguridad de la información
Formato de informes	Diagrama de radar con una categoría de recursos para cada eje y la doble indicación de los recursos asignados y usados
Relación	ISO/IEC 27001:2013, 5.1: Liderazgo y compromiso ISO/IEC 27001:2013, 7.1: Recursos



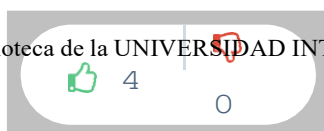
B.3 Revisión de políticas

Descriptor de información	Significado o propósito
ID de medida	Definido por la organización
Necesidad de información	Evaluar si las directivas de seguridad de la información se revisan a intervalos planificados o si se producen cambios significativos
Medida	Porcentaje de la política revisada
Fórmula/puntuación	Número de políticas de seguridad de la información que se revisaron en el año anterior/ Número de políticas de seguridad de la información en vigor * 100
Objetivo	Verde: >80, Naranja > 40%, Rojo <40%
Evidencia de implementación	Historial de documentos que menciona la revisión del documento o lista de documentos que indica la fecha de la última revisión
Frecuencia	Recopilar: después del intervalo planificado definido para las revisiones (por ejemplo, anualmente o después de cambios significativos) Informe: para cada colección
Partes responsables	Propietario de la información: Propietario de la póliza que ha aprobado la responsabilidad de la administración para el desarrollo, revisión y evaluación de la póliza Recopilador de información: Auditor interno Cliente de medición: director de seguridad de la información
Fuente de datos	Revisar el plan de políticas, sección de historial de una política de seguridad, lista de documentos
Formato de informes	Gráfico circular para la situación actual y el gráfico de líneas para la representación de la evolución del cumplimiento
Relación	ISO/IEC 27001:2013, A.5.1.2: Revisión de las políticas de seguridad de la información ISO/IEC 27001:2013, 7.5.2: Creación y actualización de información documentada

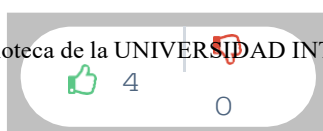


B.4 Compromiso de la gestión

Descriptor de información	Significado o propósito
ID de medida	Definido por la organización
Necesidad de información	Evaluar el compromiso de gestión y las actividades de revisión de la seguridad de la información con respecto a las actividades de revisión de la gestión
Medida	a) Reuniones de revisión de la administración completadas hasta la fecha b) Tasas medias de participación en las reuniones de revisión de la gestión hasta la fecha
Fórmula/puntuación	a) Dividir [reuniones de revisión de gestión realizadas] por [reuniones de revisión de gestión programadas] b) Calcular la media y la desviación estándar de todas las tasas de participación a las reuniones de revisión de la dirección
Objetivo	La relación resultante del indicador a) debe disminuir entre 0,7 y 1,1 para concluir el logro del objetivo de control y ninguna acción. Incluso si falla, todavía debe ser más de 0.5 para concluir el menor logro. Con respecto al indicador b), los límites de confianza calculados basados en la desviación estándar indican la probabilidad de que se alcance un resultado real cercano a la tasa media de participación. Los límites de confianza muy amplios sugieren una salida potencialmente grande y la necesidad de una planificación de contingencia para hacer frente a este resultado.
Evidencia de implementación	1.1 Contar las reuniones de revisión de gestión programadas hasta la fecha 1.2 Por reuniones de revisión de gestión hasta la fecha, los gerentes de escrutinio tenían previsto asistir y agregar una nueva entrada con un valor predeterminado para las reuniones no planificadas realizadas de manera ad hoc 2.1.1 Contar las reuniones de revisión de gestión planificadas celebradas hasta la fecha 2.1.2 Contar las reuniones de revisión de gestión no planificadas celebradas hasta la fecha 2.1.3 Contar reuniones de revisión de gestión reprogramadas celebradas hasta la fecha 2.2 Para todas las reuniones de revisión de la dirección que se celebraron, cuente el número de gerentes que asistieron.



Frecuencia	Recopilar: Mensualmente Análisis: Trimestral Informe: Trimestral Revisión de la medición: Revisar y actualizar cada 2 años Período de medición: Aplicable 2 años
Partes responsables	Propietario de la información: Administrador del sistema de calidad (asumiendo el sistema de gestión combinado de QMS e SGSI) Recopilador de información: Gestor de calidad; Gerente de seguridad de la información Cliente de medición: Gerentes responsables de SGSI; Gerente del sistema de calidad
Fuente de datos	1. Plan/programa de revisión de la gestión de la seguridad de la información 2. Actas de revisión de gestión/registros.
Formato de informes	Gráfico de líneas que representa el indicador con criterios sobre la recopilación de datos y la presentación de informes períodos con la declaración de resultados de la medición. La organización debe definir el número de períodos de recopilación de datos y de informes.
Relación	ISO/IEC 27001:2013, 9.3: Revisión de la gestión ISO/IEC 27001:2013, 5.1: Liderazgo y compromiso

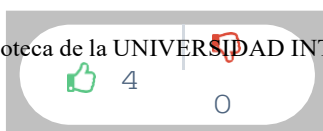


B.5 Exposición al riesgo

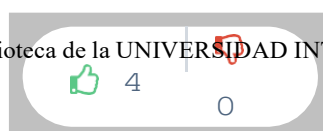
Descriptor de información	Significado o propósito
ID de medida	Definido por la organización
Necesidad de información	Evaluar la exposición de la organización a los riesgos de seguridad de la información
Medida	a) Riesgos altos y medios más allá del umbral aceptable b) Revisión oportuna de los riesgos altos y medios
Fórmula/puntuación	a) Debe definirse el umbral de riesgos altos y medios y alertar a las partes responsables si se incumple el umbral b) Número de riesgos sin actualización de estado
Objetivo	1
Evidencia de implementación	Registro de riesgos actualizado
Frecuencia	Recoger: mínimo trimestral Informe: cada trimestre
Partes responsables	Propietario de la información: Personal de seguridad Recopilador de información: Personal de seguridad
Fuente de datos	Registro de riesgos de información
Formato de informes	Tendencia de altos riesgos Tendencia de riesgos altos y medios aceptados
Relación	ISO/IEC 27001:2013, 8.2: Evaluación del riesgo de seguridad de la información ISO/IEC 27001:2013, 8.3: Tratamiento del riesgo de seguridad de la información

B.6 Programa de auditoría

Descriptor de información	Significado o propósito
ID de medida	Definido por la organización
Necesidad de información	Integridad del programa de auditoría.
Medida	Número total de auditorías realizadas en comparación con el número total de auditorías planificadas
Fórmula/puntuación	$(\text{Número total de auditorías realizadas}) / (\text{Número total de auditorías planificadas}) * 100$.
Objetivo	>95%
Evidencia de implementación	Programa de auditoría y monitoreo de informes relacionados
Frecuencia	Anual
Partes responsables	Propietario de la información: Gerente de auditoría Recopilador de información: Gestor de auditoría Cliente de información: Alta dirección
Fuente de datos	Programas de auditoría e informes de auditoría
Formato de informes	Gráfico de tendencias que vincula la proporción de auditorías completadas con respecto al programa para cada año muestreado.



Relación	ISO/IEC 27001:2013, 9.2: Auditoría interna ISO/IEC 27001:2013, A.18.2.1: Revisión independiente de la seguridad de la información
----------	--

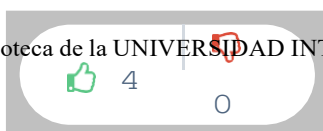


B.7 Acciones de mejora

Descriptor de información	Significado o propósito
ID de medida	Definido por la organización
Necesidad de información	Verificar el estado de las acciones de mejora y su gestión de acuerdo con los planes
Medida	Porcentaje de acciones a tiempo, costes y calidad (es decir, requisitos) contra todas las acciones planificadas Las acciones deben ser las previstas (es decir, abiertas, en espera y en curso) en el comienzo del plazo.
Fórmula/puntuación	$[(\text{Acciones a tiempo, costes y calidad}) / (\text{Número de acciones})] * 100$
Objetivo	90%
Evidencia de implementación	Monitoreo del estado de cada acción
Frecuencia	Trimestral
Partes responsables	Propietario de la información: oficina de gestión de proyectos Recopilador de información: oficina de gestión de proyectos Información Cliente: gestor de seguridad de la información
Fuente de datos	Planes de proyecto relevantes
Formato de informes	Lista de todas las acciones relevantes y su estado (tiempo real, costes y previsión de calidad con respecto a las previstas) con el porcentaje de acciones a tiempo, costes y calidad con respecto al número de acciones pertinente en el plazo previsto
Relación	ISO/IEC 27001:2013, Cláusula 10: Mejora

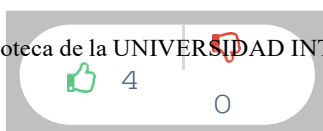
Tenga en cuenta que esta medida puede mejorarse ponderando cada acción teniendo en cuenta su criticidad (por ejemplo, acciones que abordan riesgos elevados).

Una lista de todas las acciones relevantes debe estar junto con el resultado sintético, de modo que un gran número de límites no críticos, pero dentro de los límites aceptables no oculte un número bajo de acciones críticas fuera de los límites aceptables.



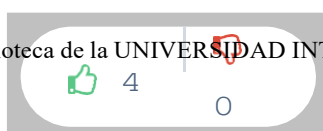
B.8 Costo del incidente de seguridad

Descriptor de información	Significado o propósito
ID de medida	Definido por la organización
Necesidad de información	Consideraciones sobre los costos derivados de la falta de seguridad de la información
Medida	Suma de costos por cada incidente de seguridad de la información ocurrido en el período de muestreo
Fórmula/puntuación	Suma (costos de cada incidente de seguridad de la información)
Objetivo	Menos de un umbral aceptable definido por la organización
Evidencia de implementación	Recopilación sistemática de costes por cada incidente de seguridad de la información
Frecuencia	Trimestral
Partes responsables	Propietario de la información: Equipo de respuesta a incidentes de seguridad informática (CSIRT) Recopilador de información: Administrador de seguridad de la información Cliente de información: Alta dirección
Fuente de datos	Informes de incidentes
Formato de informes	Gráfico de columnas que muestra los costos de los incidentes de seguridad de la información para este y los períodos de muestreo anteriores. Puede ser seguido por un desglose con: - Costo promedio de cada incidente de seguridad de la información; - Costo promedio de cada incidente de seguridad de la información para cada información categoría de incidentes de seguridad (las categorías deben definirse previamente)
Relación	ISO/IEC 27001:2013, Cláusula 10: Mejora



B.9 Aprender de incidentes de seguridad de la información

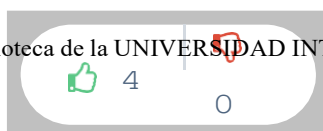
Descriptor de información	Significado o propósito
ID de medida	Definido por la organización.
Necesidad de información	Compruebe si los incidentes de seguridad desencadenan acciones para mejorar la situación de seguridad actual.
Medida	Número de incidentes de seguridad que desencadenan acciones de mejora de la seguridad de la información.
Fórmula/puntuación	Suma de incidentes de seguridad que desencadenaron acciones/Suma de incidentes de seguridad.
Objetivo	El valor debe ser superior al umbral definido por la organización.
Evidencia de implementación	Plan de acción con enlace a incidentes de seguridad.
Frecuencia	Recopilar: Trimestralmente. Informe: Cada semestre.
Partes responsables	Propietario de la información: Equipo de respuesta a incidentes de seguridad informática (CSIRT). Recopilador de información: Administrador de seguridad de la información. Cliente de información: Administrador de seguridad de la información.
Fuente de datos	Informes de incidentes
Formato de informes	Gráfico de columnas que muestra los costos de los incidentes de seguridad de la información para este y los períodos de muestreo anteriores. Puede ser seguido por un desglose con: - Costo promedio de cada incidente de seguridad de la información. - Costo promedio de cada incidente de seguridad de la información para cada información categorizada de incidentes de seguridad (las categorías deben definirse previamente).
Relación	ISO/IEC 27001:2013, Cláusula 10: Mejora ISO/IEC 27001:2013, A.16.1.6: Aprendizaje de incidentes de seguridad de la información



B.10 Implementación acción correctivo

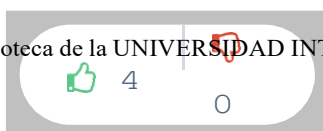
Descriptor de información	Significado o propósito
ID de medida	Definido por la organización.
Necesidad de información	Evaluar el rendimiento de la implementación de medidas correctivas.
Medida	a) Estado expresado como una proporción de medidas correctivas no implementadas. b) Estado expresado como una relación de acción correctiva no implementada sin razón. c) Tendencia de los estados.
Fórmula/puntuación	a) Dividir [Acción correctiva no implementada hasta la fecha] por [Acciones correctivas planificadas hasta la fecha] b) Dividir [Acción correctiva no implementada sin razón] por [Acciones correctivas planificadas hasta la fecha] c) Comparar estados con estados anteriores
Objetivo	Para concluir el logro del objetivo y ninguna acción, las proporciones del indicador a) y b) deberían disminuir respectivamente entre 0,4 y 0,0 y entre 0,2 y 0,0, y la tendencia del indicador c) debería haber disminuido durante los últimos 2 períodos de presentación de informes. El indicador c) debe presentarse en comparación con los indicadores anteriores para que pueda examinarse la tendencia en la aplicación de la acción correctiva.
Evidencia de implementación	1. Contar las acciones correctivas planeadas para ser implementadas hasta la fecha 2. Contar las acciones correctivas registradas como implementadas antes de la fecha de vencimiento 3. Contar las acciones correctivas registradas como acciones planificadas no tomadas con la razón
Frecuencia	Recopilar: Trimestralmente Análisis: Trimestral Informe: Trimestral Revisión de medición: Revisión anualmente Período de medición: Aplicable 1 año.
Partes responsables	Propietario de la información: Gerentes responsables de SGSI Recopilador de información: Gerentes responsables de SGSI Cliente de medición: Gerentes responsables de SGSI; Gerente de seguridad de la información
Fuente de datos	Informes de acciones correctivas

Formato de informes	Gráfico de barras apiladas con la declaración de resultados de medición que incluye un resumen ejecutivo de los hallazgos y posibles acciones de gestión, que representa el número total de acciones correctivas, separadas en implementadas, no implementadas sin una razón legítima, y no implementadas con una razón legítima.
Relación	ISO/IEC 27001:2013, 10.1: Inconformidad y acción correcta

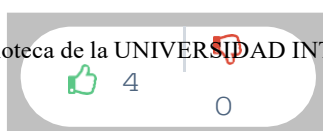


B.11 Entrenamiento SGSI o conciencia SGSI

Descriptor de información	Significado o propósito
ID de medida	Definido por la organización
Necesidad de información	Para medir cuantos empleados recibieron una capacitación de concientización relacionada con el SGSI y establecer el cumplimiento de control con la política de seguridad de la información de la organización.
Medida	Porcentaje de empleados que participaron en una capacitación de concientización sobre el SGSI.
Fórmula/puntuación	$I1 = \left[\frac{\text{Número de empleados que recibieron capacitación SGSI}}{\text{Número de empleados que deben recibir capacitación SGSI}} \right] * 100.$ $I2 = \left[\frac{\text{Número de empleados que renovaron su capacitación SGSI en el último año}}{\text{Número de empleados en alcance}} \right] * 100.$
Objetivo	Verde: Si $I1 > 90$ e $I2 > 50\%$ de lo contrario amarillo: Si $I1 > 60\%$ e $I2 > 30\%$ de lo contrario rojo. — Rojo: Se requiere intervención, se deben realizar un análisis de causalidad para determinar las razones del incumplimiento y el bajo rendimiento. — Amarillo: se debe vigilar de cerca el indicador para detectar un posible deslizamiento de Rojo. — Verde: no se requiere ninguna acción.
Evidencia de implementación	Listas de participación de todos los entrenamientos de sensibilización; recuento de registros/registros con campo de entrenamiento SGSI/relleno de fila como "recibido".
Frecuencia	Recopilación: Mensual, primer día hábil del mes. Análisis: Trimestral. Informe: Trimestral. Revisión de medición: Revisar anualmente. Periodo de medición: Anual.
Partes responsables	Propietario de la información: Gerente de formación – Recursos Humanos. Recopilador de información: Gestión de la formación - Departamento de recursos humanos. Cliente de medición: Gerentes responsables de un SGSI, director de seguridad de la información.
Fuentes de datos	Base de datos empleados, registros de capacitación, lista de participación de capacitaciones de concientización.

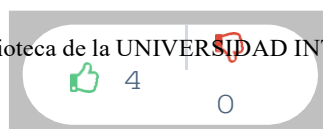


Formato de informe	Gráfico de barras, con barras codificadas por colores según el objetivo. Un breve resumen de lo que significa la medida y las posibles acciones de gestión deben adjuntarse al gráfico de barras o gráfico circular para la situación actual y gráfico lineal para la representación de la evolución del cumplimiento.
Relación	ISO/IEC 27001:2013, A.7.2: Competencia.



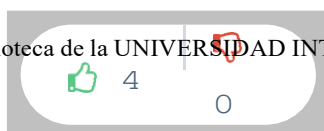
B.12 Capacitación en seguridad de la información

Descriptor de Información	Significado o propósito
ID de medida	Definido por la organización.
Necesidad de Información	Evaluar el cumplimiento del requisito anual de capacitación en concientización sobre seguridad de la información.
Medida	Porcentaje del personal que recibió capacitación anual en concientización sobre seguridad de la información.
Fórmula/puntuación	$\left[\frac{\text{Número de empleados que recibieron capacitación anual en concientización de seguridad de la información}}{\text{Número de empleados que necesitan recibir capacitación anual en concientización de seguridad de la información}} \right] * 100.$
Objetivo	0-60% - Rojo; 60-90% - Amarillo; 90-100% Verde. Para Amarillo, si no se logra un progreso de al menos el 10% por trimestre, la calificación es automáticamente roja. Rojo: se requiere intervención, se debe realizar un análisis de causalidad para determinar las razones del incumplimiento y el bajo rendimiento. Amarillo: el indicador debe vigilarse de cerca para detectar un posible deslizamiento a rojo. Verde: no se requiere ninguna acción.
Evidencia de Implementación	Recuento de registros/registros con campo de formación de conciencia de seguridad de información anual/relleno de fila como "recibido".
Frecuencia	Recopilar: Mensualmente, primer día laborable del mes Análisis: Trimestral. Informe: Trimestral. Revisión de medición: Revisar anualmente. Periodo de medición: Anual.
Partes responsables	Propietario de la información: Oficial de seguridad de la información y Gerente de capacitación. Recopilación de información: Gestión de la capacitación – Departamento de recursos humanos. Cliente de medición: Gerentes responsables de un SGSI; gestión de seguridad; gestión de la información.
Fuente de datos	Base de datos de empleados, registros de entrenamiento.
Formato de Informe	Gráfico de barras con barras codificadas por colores según el objetivo. Un breve resumen de lo que significa la medida y las posibles acciones de gestión deben adjuntarse al grafico de barras.
Relación	ISO/IEC 27001:2013, A.7.2.2: Concienciación sobre la seguridad de la información, educación y capacitación.

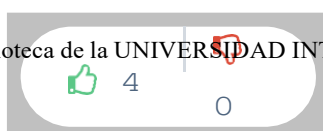


B.13 Cumplimiento de la conciencia de seguridad de la información

Descriptor de información	Significado o propósito
ID de medida	Definido por la organización
Necesidad de información	Evaluar el estado de cumplimiento de la política de conciencia de seguridad de la organización entre el personal relevante
Medida	1. Progreso hasta la fecha 2. Progreso hasta la fecha con la firma
Fórmula / puntuación	Obtenga el "progreso hasta la fecha" agregando el estado de todo el personal que ha firmado, planeado para completarse hasta la fecha Obtenga "progreso hasta la fecha con la firma" dividiendo el personal que ha firmado hasta la fecha por el personal planificado para la firma hasta la fecha a) [divida el progreso hasta la fecha entre (personal planificado hasta la fecha multiplicado por 100)] y avance hasta la fecha con la firma. b) Compare el estado con estados anteriores.
Objetivo	a) Las proporciones resultantes deberían caer respectivamente entre 0.9 y 1.1 y entre 0.99 y 1.01 para concluir el logro del objetivo de control y ninguna acción; y b) La tendencia debe ser al alza o estable.
Evidencia de implementación	1.1. Contar el número de personal programado para haber firmado y completado la capacitación hasta la fecha. 1.2. Pídale a la persona responsable el porcentaje de personal que ha completado la capacitación y firmado. 2.1. Contar el número de personal programado para haber firmado en esta fecha. 2.2. Contar el número de personal que ha firmado acuerdos de usuario.
Frecuencia	Recopilar: Mensualmente, primer día laborable del mes. Informe: Trimestral. Revisión de medición: Revisar anualmente. Período de medición: Anual
Partes responsables	Propietario de la información: oficial de seguridad de la información y gerente de capacitación. Recopilador de información: administración de la capacitación; Departamento de recursos humanos Cliente de medición: gerentes responsables de un SGSI; Gestión de seguridad. gestión de la información.



Fuente de datos	1.1. Plan / programa de capacitación de concientización sobre seguridad de la información: personal identificado en el plan. 1.2 Personal que ha completado o en progreso en la capacitación: estado del personal con respecto a la capacitación. 2.1. Plan para firmar acuerdos / horario de usuario: Personal identificado en el plan para firmar 2.2. Personal que ha firmado acuerdos: estado del personal con respecto a la firma de acuerdos
Formato de informe	Fuente estándar = Los criterios se han cumplido satisfactoriamente. Fuente en cursiva = Los criterios se ha cumplido de forma insatisfactoria. Fuente en negrita = No se han cumplido los criterios.
Relación	ISO / IEC 27001: 2013, A.7.2.2: Responsabilidades de gestión. ISO/IEC 27001:2013, A.7.2.1: Conciencia de seguridad de la información, educación y capacitación.



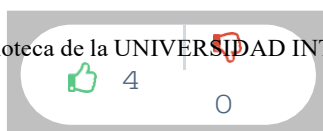
B.14 Eficacia de las campañas de sensibilización del SGSI

Descriptor de información	Significado o propósito
ID de medida	Definido por la organización.
Necesidad de información	Para medir si los empleados han entendido el contenido de la campaña de concienciación
Medida	Porcentaje de empleados que pasan una prueba de conocimiento antes y después de la campaña de concienciación del SGSI
Fórmula / puntuación	Elija un número determinado de empleados que fueron blanco de una campaña de concienciación y permítales completar una breve prueba de conocimientos sobre temas de la campaña de concienciación Porcentaje de personas que pasaron la prueba
Objetivo	Verde: 90-100% de las personas pasaron la prueba, Naranja: 60-90% de las personas pasaron la prueba, Rojo: <60% de las personas pasaron la prueba
Evidencia de implementación	Documentos de campaña de concienciación/información proporcionada a los empleados; lista de empleados que siguieron la campaña de sensibilización; pruebas de conocimiento
Frecuencia	Recoger: un mes después de la campaña de concienciación Informe: para cada colección
Partes responsables	Propietario de la información: Recursos humanos Coleccionista de información: Recursos humanos Cliente de medición: Gestor de seguridad de la información
Fuente de datos	Base de datos de empleados, información de la campaña de concienciación, resultados de las pruebas de conocimiento
Formato de informe	Gráfico circular para representar al porcentaje de miembros del personal pasó la situación de la prueba y el gráfico de líneas para la representación de la evolución si se ha organizado una formación adicional para un tema específico
Relación	ISO/IEC 27001:2013, A.7.2.2: Concienciación sobre la seguridad de la información, educación y entrenamiento.

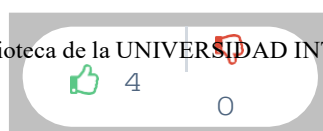


B.15 Preparación de ingeniería social

Descriptor de información	Significado o propósito
ID de medida	Definido por la organización
Necesidad de información	Evaluar si el personal está preparado para reaccionar adecuadamente en caso de algunos ataques de ingeniería social.
Medida	Porcentaje del personal que reacciona correctamente a una prueba, por ejemplo, que no hizo clic en un enlace en una prueba dada que consiste en enviar un correo electrónico de suplantación de identidad (una parte seleccionada del personal).
Fórmula / puntuación	a = Número de personal que ha hecho clic en el enlace / número de personal que participa en la prueba $b = 1 - \text{Número de personal que ha informado el correo electrónico peligroso a través de los canales apropiados}$ c = Número de empleados que han seguido las instrucciones dadas al hacer clic en el enlace, es decir, comenzar a revelar una contraseña / número de miembros del personal que participan. d = Una suma ponderada apropiada del parámetro anterior, dependiendo de la naturaleza de la prueba.
Objetivo	d: 0-60: rojo, 60-80: amarillo, 90-100: verde
Evidencia de implementación	Recuento de actividad en un comando y control simulado dirigido por el enlace. Tenga cuidado de respetar los aspectos de privacidad del personal y anonimizar los datos para que los participantes de la prueba no tengan que temer las consecuencias negativas de esta prueba.
Frecuencia	Recopilación: mensual a anual, según la importancia de los ataques de ingeniería social. Informe: para cada recopilación
Partes responsables	Propietario de la información: director de seguridad de la información Recopilador de información: oficial de seguridad de TI capacitado para respetar aspectos de privacidad Cliente de medición: Propietario del riesgo
Fuente de datos	Lista de personal o usuarios de un servicio dado; Soporte de sensibilización, comunicación (correo electrónico o intranet).
Formato de informe	Informe de la prueba que indica los detalles de la prueba, las mediciones, el análisis de los resultados y la recomendación, según el objetivo y el tratamiento acordado.



Relación	ISO/IEC 27001:2013, A.16.1: Gestión de incidentes de seguridad de la información y mejoras. ISO/IEC 27001:2013, A.9.3.1: Uso de información de autenticación secreta. ISO/IEC 27001:2013, A.7.2.2: Conocimiento, educación y capacitación sobre seguridad de la información.
----------	---

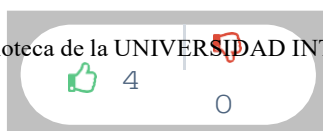


B.16 Calidad de contraseña - manual

Descriptor de información	Significado o propósito
ID de medida	Definido por la organización
Necesidad de información	Evaluar la calidad de las contraseñas utilizadas por los usuarios para acceder a los sistemas de TI de la organización.
Medida	Número total de contraseñas que cumplen con la política de calidad de contraseña de la organización. a) Relación de contraseñas que cumplen con la política de calidad de contraseña de la organización b) Tendencias del estado de cumplimiento con respecto a la política de calidad de contraseña
Fórmula / puntuación	Contar el número de contraseñas en la base de datos de contraseñas de usuario Determinar el número de contraseñas que satisfacen la política de contraseña de la organización Σ de [Número total de contraseñas que cumplen con la política de calidad de contraseña de la organización para cada usuario] a) Relación de contraseñas que cumplen con la política de calidad de contraseña de la organización b) Tendencias del estado de cumplimiento con respecto a la política de calidad de contraseña c) Dividir [Número total de contraseñas cumplidas con la política de calidad de contraseña de la organización] por [Número de contraseñas registradas] d) Compare la relación con la relación anterior
Objetivo	Se logra el objetivo de control y no se requiere acción si la relación resultante es superior 0.9. Si la relación resultante está entre 0,8 y 0,9, el objetivo de control no se logra, pero la tendencia positiva indica una mejora. Si la relación resultante es inferior a 0,8, se deben tomar medidas inmediatas.
Evidencia de implementación	1Cuenta el número de contraseñas en la base de datos de contraseñas de usuario 2Determine el número de contraseñas que satisfacen la política de contraseñas de la organización Archivo de configuración, configuración de contraseña o herramienta de configuración

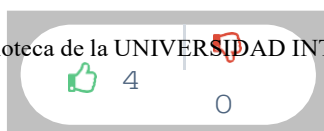


Frecuencia	Recopilar: Dependiendo de la criticidad, pero el mínimo anual Análisis: Después de cada colección Informe: Después de cada análisis Revisación de medición: Anualmente Período de medición: Anual
Partes responsables	Propietario de la información: administrador del sistema. Recopilador de información: personal de seguridad. Cliente de medición: gerentes responsables de un SGSI, gerente de seguridad
Fuente de datos	Base de datos de contraseñas de usuario; Contraseñas individuales
	Línea de tendencia que representa el número de contraseñas que cumplen con la política de calidad de contraseña de la organización, superpuesta con líneas de tendencia producidas durante períodos de informes anteriores.
Relación	ISO / IEC 27001: 2013, A.9.3.1: Uso de información secreta de autenticación



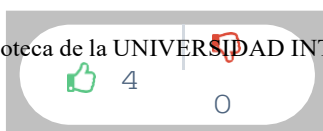
B.17 Calidad de contraseña - automatizada

Descriptor de información	Significado o propósito
ID de medida	Definido por la organización
Necesidad de información	Evaluar la calidad de las contraseñas utilizadas por los usuarios para acceder a los sistemas de TI de la organización.
Medida	1 Número total de contraseñas 2 Número total de contraseñas no descifrables
Fórmula / puntuación	1 relación de contraseñas descifrables en 4 horas 2 Tendencia de la relación 1 a) Divida [Número de contraseñas no descifrables] por [Número total de contraseñas] b) Compare la relación con la relación anterior
Objetivo	Se logra el objetivo de control y no se requiere acción si la relación resultante es superior 0.9. Si la relación resultante está entre 0,8 y 0,9, el objetivo de control no se logra, pero la tendencia positiva indica una mejora. Si la relación resultante es inferior a 0,8, se deben tomar medidas inmediatas.
Evidencia de implementación	1 Ejecutar consulta en registros de cuenta de empleado 2 Ejecute el descifrador de contraseñas en los registros de cuentas del sistema de los empleados mediante un ataque híbrido
Frecuencia	Recopilar: Semanalmente Análisis: Semanalmente Informe: Semanalmente Revisión de la medición: Revisar y actualizar cada año Período de medición: Aplicable 3 años
Partes responsables	Propietario de la información: administrador del sistema. Recopilador de información: personal de seguridad. Cliente de medición: gerentes responsables de un SGSI, gerente de seguridad
Fuente de datos	Base de datos de la cuenta del sistema del empleado
Formato de informe	Línea de tendencia que representa la posibilidad de descifrar contraseñas para todos los registros probados superpuestos con líneas producidas durante pruebas anteriores.
Relación	ISO / IEC 27001: 2013, A.9.3.1: Uso de información secreta de autenticación



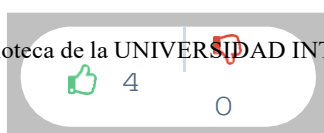
B.18 Revisión de los derechos de acceso del usuario

Descriptor de información	Significado o propósito
ID de medida	Definido por la organización
Necesidad de información	Mida la cantidad de revisiones sistemáticas de derechos de acceso de usuarios que se realizan en sistemas críticos
Medida	Porcentaje de sistemas críticos donde los derechos de acceso de los usuarios se revisan periódicamente
Fórmula / puntuación	$\left[\frac{\text{Número de sistemas de información clasificados como críticos donde se realizan revisiones periódicas de los derechos de acceso}}{\text{Número total de sistemas de información clasificados como críticos}} \right] * 100$
Objetivo	Verde: 90-100%, Naranja: 70-90%, Rojo <70%
Evidencia de implementación	Pruebas de revisiones (por ejemplo, correo electrónico, ticket en el sistema de ventas de entradas, finalización de revisión de revisión de fórmula).
Frecuencia	Recopilar: después de cualquier cambio, como promoción, degradación o finalización del empleo Informe: cada semestre
Partes responsables	Propietario de la información: Propietario del riesgo Recopilador de información: director de seguridad de la información Cliente de medición: Gestor de seguridad de la información
Fuente de datos	Inventario de activos, sistema utilizado para rastrear si se realizaron revisiones, por ejemplo, sistema de entradas.
Formato de informe	Gráfico circular para la situación actual y gráfico lineal para la representación de la evolución del cumplimiento.
Relación	ISO / IEC 27001: 2013, A.9.2.5: Revisión de los derechos de acceso del usuario



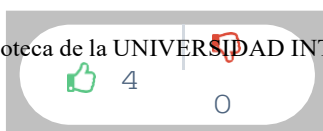
B.19 Evaluación del sistema de controles de entrada física

Descriptor de información	Significado o propósito
ID de medida	Definido por la organización
Necesidad de información	Mostrar la existencia, extensión y calidad del sistema utilizado para el control de acceso.
Medida	Fuerza del sistema de controles de entrada física.
Fórmula/puntuación	Escala de 0 a 5 0 no hay un sistema de control de acceso 1. Hay un sistema de acceso donde se utiliza el código PIN (sistema de un factor) se utiliza para el control de entrada. 2. Hay un sistema de tarjeta de control de acceso donde se utiliza la tarjeta de pase (sistema de un factor) para el control de entrada. 3. Hay un sistema de tarjeta de acceso donde se utiliza la tarjeta de acceso y el código PIN para el control de entrada. 4. Funcionalidad de registro activado 5. El código anterior + PIN se reemplaza por la autenticación biométrica (huella digital, reconocimiento de voz, escaneo de retina, etc.)
Objetivo	Valor 3 = satisfactorio
Evidencia de implementación	Evaluación cualitativa donde cada calificación de subconjunto es una parte de la calificación anterior. Controle el tipo de sistema de control de entrada e inspeccione los siguientes aspectos: - Existencia del sistema de tarjeta de control de acceso - Uso del código PIN - Funcionalidad de registro - Autenticación biométrica
Frecuencia	Recopilar: Anualmente Análisis: Anual Informe: Anualmente Revisión de la medición: 12 meses Período de medición: Aplicable 12 meses
Partes responsables	Propietario de la información: Gerente de la instalación Recopilador de información: Auditor interno/auditor externo Cliente de medición: Comité de gestión
Fuente de datos	Registros de gestión de identidades
Formato de informes	Gráficos
Relación	ISO/IEC 27001:2013, A.11.1.2: Controles de entrada física.



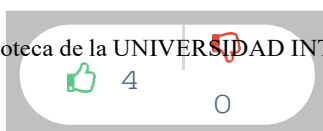
B.20 La entrada física controla la efectividad

Descriptor de información	Significado o propósito
ID de medida	Definido por la organización
Necesidad de información	1. Garantizar un entorno de seguridad integral y responsabilidad para el personal, las instalaciones y los productos. 2. Integrar mecanismos de protección de la seguridad física y de la información para garantizar la protección adecuada de los recursos de información de la organización
Medida	Número de entrada no autorizada a instalaciones que contienen sistemas de información (subconjunto de incidentes de seguridad física).
Fórmula/puntuación	Número actual de incidentes de seguridad física que permiten la entrada no autorizada a instalaciones que contienen sistemas de información / valor anterior (tenga en cuenta que estas medidas deben tener en cuenta el contexto específico de la organización, como el número total de incidentes de seguridad física).
Objetivo	Por debajo de 1.0
Evidencia de implementación	Análisis sistemático de informes de incidentes de seguridad física y registros de control de acceso.
Frecuencia	Trimestralmente para la recopilación de datos e informes.
Partes responsables	Propietario de la información: Oficial de seguridad física. Recopilador de información: Equipo de respuesta a incidentes de seguridad informática (CSIRT). Cliente de información: director de información, director de seguridad de la información.
Fuente de datos	Informes de incidentes de seguridad física. Registros de control de acceso físico.
Formato de informes	Gráfico que muestra la tendencia de la entrada no autorizada a instalaciones que contienen sistemas de información para los períodos de muestreo más recientes.
Relación	ISO/IEC 27001:2013, A. 11.1.2: Controles de entrada física.
Acción	Revisar y mejorar los controles de seguridad física aplicados a los sistemas de información.



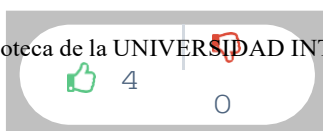
B.21 Gestión del mantenimiento periódico

Descriptor de información	Significado o propósito
ID de medida	Definido por la organización.
Necesidad de información	Evaluar la puntualidad de las actividades de mantenimiento en relación con el cronograma.
Medida	Retraso de mantenimiento por evento de mantenimiento completado.
Fórmula/puntuación	Para cada evento completado, reste [Fecha de mantenimiento real] de [Fecha de mantenimiento programado].
Objetivo	1. Específico de la organización, por ejemplo, si el retraso promedio se muestra de manera consistente en más de 3 días, las causas deben ser examinadas. 2. La proporción de eventos de mantenimiento completados debe ser mayor a 0,9. 3. La tendencia debe ser estable o cerca de 0. 4. La tendencia debe ser estable o superior.
Evidencia de implementación	1 fechas de mantenimiento programado. 2 fechas de mantenimiento completado. 3 número total de eventos de mantenimiento planificados. 4 número total de eventos de mantenimiento completados.
Frecuencia	Recoger: Trimestral Informe: anualmente
Partes responsables	Propietario de la información: Administrador del sistema. Recopilador de información: Personal de seguridad. Cliente de medición: Gerente de seguridad, Gerente de TI.
Fuente de datos	1 plan/programa de mantenimiento del sistema. 2 registros de mantenimientos del sistema.
Formato	Gráfico de líneas que representa la desviación promedio del retraso de mantenimiento, superpuesta con líneas producidas durante períodos de informes anteriores y la cantidad de sistemas dentro del alcance. Una explicación de los hallazgos y la recomendación para una posible acción de gestión.
Relación	ISO/IEC 27001:2013, A. 11.2.4: Mantenimiento del equipo



B.22 Gestión del cambio

Descriptor de información	Significado o propósito
ID de medida	Definido por la organización.
Necesidad de información	Evaluar si se respetan las mejores prácticas de gestión de cambios y la política de endurecimiento.
Medida	Porcentaje de nuevos sistemas instalados que se respetaron las mejores prácticas de gestión de cambios y la política de endurecimiento.
Fórmula/puntuación	Número de aplicaciones o sistemas recién instalados en los que hay evidencias de respetar de las mejores prácticas de gestión de cambios/número de aplicaciones recién instaladas.
Objetivo	Todos los sistemas deben seguir las pautas de gestión de cambios.
Evidencia de implementación	Sistema de tickets, correos electrónicos, informes, lista de verificación utilizada para la configuración.
Frecuencia	Recopilar: Cada semestre. Informe: Anualmente a la gerencia, cada semestre al gerente de seguridad de la información.
Partes responsables	Propietario de la información: Propietario del riesgo. Coleccionista de información: Propietario del riesgo. Cliente de medición: Gerente de seguridad de la información.
Fuente de datos	Sistema de tickets, correos electrónicos, informes, lista de comprobación utilizada para la configuración, informe de la herramienta de revisión de la configuración.
Formato de informes	Gráfico circular para la situación actual y el gráfico de líneas para la representación de la evolución del cumplimiento.
Relación	ISO/IEC 27001:2013, A. 12.1.2: Gestión de cambios



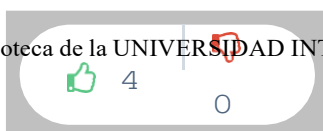
B.23 Protección contra código malicioso

Descriptor de información	Significado o propósito
ID de medida	Definido por la organización.
Necesidad de información	Evaluar la efectividad del sistema de protección contra ataques de software malintencionados.
Medida	Tendencia de los ataques detectados que no se bloquearon durante varios períodos de informes.
Fórmula/puntuación	Número de incidentes de seguridad causados por software malicioso/número de ataques detectados y bloqueados causados por el software malicioso.
Objetivo	La línea de tendencia debe permanecer bajo la referencia especificada, dando como resultado una tendencia descendente o constante.
Evidencia de implementación	1 cuenta el número de incidentes de seguridad causados por software malicioso en los informes de incidentes. 2 cuenta el número de registros de ataques bloqueados.
Frecuencia	Recopilar: Todos los días. Análisis: Mensualmente. Informe: Mensualmente. Revisión de medición: Revisar anualmente. Período de medición: Aplicable 1 año.
Partes responsables	Propietario de la información. Coleccionista de información. Cliente de medición.
Fuente de datos	1 informes de incidentes. 2 registros de software de contramedida para software malicioso.
Formato de informes	Línea de tendencia que representa la proporción de detección y prevención de software malicioso con líneas producidas durante períodos de informes anteriores.
Relación	ISO/IEC 27001:2013, A.12.2.1: Controles contra malware.

NOTA:

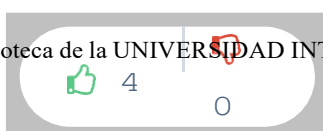
Las organizaciones que adopten esta medida deben tener en cuenta los siguientes problemas que pueden dar lugar a un análisis incorrecto de dicha medida:

- "El número de ataques detectados y bloqueados causados por software malicioso" puede ser muy alto; por lo tanto, tal medida puede dar lugar a proporciones muy pequeñas;
- Si en un período hay un aumento de la propagación de un virus específico, una organización puede experimentar un aumento de los ataques e incidentes de malware; en este caso la proporción sigue siendo la misma, incluso si el aumento de incidentes puede generar preocupación.



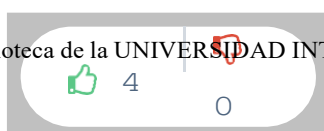
B.24 Anti - malware

Descriptor de información	Significado o propósito
ID de medida	Definido por la organización.
Necesidad de información	Número de sistemas afectados por malware que no tienen una solución anti-malware actualizada.
Medida	Porcentaje de sistemas afectados por malware conectados a la red de la organización con firmas obsoletas (por ejemplo, más de una semana).
Fórmula/puntuación	(Número de antivirus obsoleto) / (Estación de trabajo total).
Objetivo	0 o un pequeño valor decidido por la organización.
Evidencia de implementación	Seguimiento de las actividades antivirus en cada sistema afectado por malware.
Frecuencia	Diario.
Partes responsables	Propietario de la información: Operaciones de TI. Recopilador de información: Operaciones de TI. Cliente de información: director de seguridad de la información.
Fuente de datos	Herramientas de monitoreo. Consola antimalware.
Formato de informes	Números por clases de sistema (estaciones de trabajo, servidores, o/s).
Relación	ISO/IEC 27001:2013, A.12.2.1: Controles contra malware



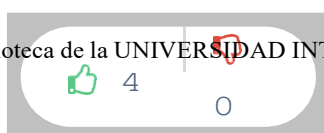
B.25 Disponibilidad total

Descriptor de información	Significado o propósito
ID de medida	Definido por la organización
Necesidad de información	Disponibilidad de servicios de TI para cada servicio, en comparación con el tiempo de inactividad máximo definido.
Medida	Para cada servicio de TI, la disponibilidad de extremo a extremo se compara con la disponibilidad máxima (es decir, excluyendo las ventanas de tiempo de inactividad definidas anteriormente).
Fórmula/puntuación	(Disponibilidad total) / (Disponibilidad máxima excluyendo ventanas de tiempo de inactividad).
Objetivo	Objetivo de disponibilidad del servicio.
Evidencia de implementación	Supervisión de la disponibilidad integral de cada servicio de TI.
Frecuencia	Mensual.
Partes responsables	Propietario de la información: Operaciones de TI. Recopilador de información: Calidad de TI. Cliente de información: director de información.
Fuente de datos	Herramientas de monitoreo.
Formato de informes	Para cada servicio, dos líneas: 1. línea que vincula la disponibilidad real (porcentaje) de cada período muestreado. 2. línea (para fines de comparación) que muestra el objetivo de disponibilidad.
Relación	ISO/IEC 27001:2013, A.17.2.1: Disponibilidad de instalaciones de procesamiento de información



B.26 Reglas de cortafuego

Descriptor de información	Significado o propósito
ID de medida	Definido por la organización.
Información necesaria	Evalúa el rendimiento actual del cortafuegos.
Medida	Reglas de cortafuego no utilizadas en cortafuegos fronterizos.
Fórmula/puntuación	Recuento de reglas de cortafuegos fronterizos que se han utilizado 0 veces en el último período de muestreo.
Objetivo	0
Evidencia de implementación	Registros de contadores de uso en cada regla de cortafuegos.
Frecuencia	Bianual o anual.
Partes responsables	Propietario de la información: Administrador de red/administrador de seguridad de la información. Recopilador de información: Analista de red/analista de seguridad. Cliente de información: Gerente de red/administrador de seguridad de la información.
Fuente de datos	Consola de administración de cortafuegos, informe de revisión de cortafuegos.
Formato de informe	Cuenta o enumere de reglas de cortafuegos no utilizadas que se marcarán para su revisión y posible eliminación.
Relación	ISO/IEC 27001:2013, A.13.1.3: Segregación en redes.



B.7 Acciones de mejora

Descriptor de información	Significado o propósito
ID de medida	Definido por la organización
Necesidad de información	Verificar el estado de las acciones de mejora y su gestión de acuerdo con los planes
Medida	Porcentaje de acciones a tiempo, costes y calidad (es decir, requisitos) contra todas las acciones planificadas Las acciones deben ser las previstas (es decir, abiertas, en espera y en curso) en el comienzo del plazo.
Fórmula/puntuación	$[(\text{Acciones a tiempo, costes y calidad}) / (\text{Número de acciones})] * 100$
Objetivo	90%
Evidencia de implementación	Monitoreo del estado de cada acción
Frecuencia	Trimestral
Partes responsables	Propietario de la información: oficina de gestión de proyectos Recopilador de información: oficina de gestión de proyectos Información Cliente: gestor de seguridad de la información
Fuente de datos	Planes de proyecto relevantes
Formato de informes	Lista de todas las acciones relevantes y su estado (tiempo real, costes y previsión de calidad con respecto a las previstas) con el porcentaje de acciones a tiempo, costes y calidad con respecto al número de acciones pertinente en el plazo previsto
Relación	ISO/IEC 27001:2013, Cláusula 10: Mejora

Tenga en cuenta que esta medida puede mejorarse ponderando cada acción teniendo en cuenta su criticidad (por ejemplo, acciones que abordan riesgos elevados).

Una lista de todas las acciones relevantes debe estar junto con el resultado sintético, de modo que un gran número de límites no críticos, pero dentro de los límites aceptables no oculte un número bajo de acciones críticas fuera de los límites aceptables.



Descriptor de información	Significado o propósito
ID de medida	Definido por la organización
Necesidad de información	Consideraciones sobre los costos derivados de la falta de seguridad de la información
Medida	Suma de costos por cada incidente de seguridad de la información ocurrido en el período de muestreo
Fórmula/puntuación	Suma (costos de cada incidente de seguridad de la información)
Objetivo	Menos de un umbral aceptable definido por la organización
Evidencia de implementación	Recopilación sistemática de costes por cada incidente de seguridad de la información
Frecuencia	Trimestral
Partes responsables	Propietario de la información: Equipo de respuesta a incidentes de seguridad informática (CSIRT) Recopilador de información: Administrador de seguridad de la información Cliente de información: Alta dirección
Fuente de datos	Informes de incidentes
Formato de informes	Gráfico de columnas que muestra los costos de los incidentes de seguridad de la información para este y los períodos de muestreo anteriores. Puede ser seguido por un desglose con: - Costo promedio de cada incidente de seguridad de la información; - Costo promedio de cada incidente de seguridad de la información para cada información categoría de incidentes de seguridad (las categorías deben definirse previamente)
Relación	ISO/IEC 27001:2013, Cláusula 10: Mejora



B.9 Aprender de incidentes de seguridad de la información

Descriptor de información	Significado o propósito
ID de medida	Definido por la organización.
Necesidad de información	Compruebe si los incidentes de seguridad desencadenan acciones para mejorar la situación de seguridad actual.
Medida	Número de incidentes de seguridad que desencadenan acciones de mejora de la seguridad de la información.
Fórmula/puntuación	Suma de incidentes de seguridad que desencadenaron acciones/Suma de incidentes de seguridad.
Objetivo	El valor debe ser superior al umbral definido por la organización.
Evidencia de implementación	Plan de acción con enlace a incidentes de seguridad.
Frecuencia	Recopilar: Trimestralmente. Informe: Cada semestre.

Partes responsables	Propietario de la información: Equipo de respuesta a incidentes de seguridad informática (CSIRT). Recopilador de información: Administrador de seguridad de la información. Cliente de información: Administrador de seguridad de la información.
Fuente de datos	Informes de incidentes
Formato de informes	Gráfico de columnas que muestra los costos de los incidentes de seguridad de la información para este y los períodos de muestreo anteriores. Puede ser seguido por un desglose con: - Costo promedio de cada incidente de seguridad de la información. - Costo promedio de cada incidente de seguridad de la información para cada información categorizada de incidentes de seguridad (las categorías deben definirse previamente).
Relación	ISO/IEC 27001:2013, Cláusula 10: Mejora ISO/IEC 27001:2013, A.16.1.6: Aprendizaje de incidentes de seguridad de la información

B.10 Implementación acción correctivo

Descriptor de información	Significado o propósito
ID de medida	Definido por la organización.
Necesidad de información	Evaluar el rendimiento de la implementación de medidas correctivas.
Medida	a) Estado expresado como una proporción de medidas correctivas no implementadas. b) Estado expresado como una relación de acción correctiva no implementada sin razón. c) Tendencia de los estados.
Fórmula/puntuación	a) Dividir [Acción correctiva no implementada hasta la fecha] por [Acciones correctivas planificadas hasta la fecha] b) Dividir [Acción correctiva no implementada sin razón] por [Acciones correctivas planificadas hasta la fecha] c) Comparar estados con estados anteriores
Objetivo	Para concluir el logro del objetivo y ninguna acción, las proporciones del indicador a) y b) deberían disminuir respectivamente entre 0,4 y 0,0 y entre 0,2 y 0,0, y la tendencia del indicador c) debería haber disminuido durante los últimos 2 períodos de presentación de informes. El indicador c) debe presentarse en comparación con los indicadores anteriores para que pueda examinarse la tendencia en la aplicación de la acción correctiva.
Evidencia de implementación	1. Contar las acciones correctivas planeadas para ser implementadas hasta la fecha 2. Contar las acciones correctivas registradas como implementadas antes de la fecha de vencimiento 3. Contar las acciones correctivas registradas como acciones

	planificadas no tomadas con la razon
Frecuencia	Recopilar: Trimestralmente Análisis: Trimestral Informe: Trimestral Revisión de medición: Revisión anualmente Período de medición: Aplicable 1 año.
Partes responsables	Propietario de la información: Gerentes responsables de SGSI Recopilador de información: Gerentes responsables de SGSI Cliente de medición: Gerentes responsables de SGSI; Gerente de seguridad de la información
Fuente de datos	Informes de acciones correctivas

© ISO/IE - Todo Derechos Reservados

Este documento forma parte de la biblioteca de la UNIVERSIDAD INTERNACIONAL DE LA RIOJA

Formato de informes	Gráfico de barras apiladas con la declaración de resultados de medición que incluye un resumen ejecutivo de los hallazgos y posibles acciones de gestión, que representa el número total de acciones correctivas, separadas en implementadas, no implementadas sin una razón legítima, y no implementadas con una razón legítima.
Relación	ISO/IEC 27001:2013, 10.1: Inconformidad y acción correcta

B.11 Entrenamiento SGSI o conciencia SGSI

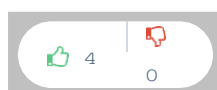
Descriptor de información	Significado o propósito
ID de medida	Definido por la organización
Necesidad de información	Para medir cuantos empleados recibieron una capacitación de concientización relacionada con el SGSI y establecer el cumplimiento de control co ⁴ n la ₀ política de seguridad de la información de la organización.

Medida	Porcentaje de empleados que participaron en una capacitación de concientización sobre el SGSI.
Fórmula/puntuación	$I1 = [\text{Número de empleados que recibieron capacitación SIMS} / \text{Número de empleados que deben recibir capacitación SGSI}] * 100.$ $I2 = [\text{Número de empleados que renovaron su capacitación SGSI en el último año} / \text{Número de empleados en alcance}] * 100.$
Objetivo	Verde: Si $I1 > 90$ e $I2 > 50\%$ de lo contrario amarillo: Si $I1 > 60\%$ e $I2 > 30\%$ de lo contrario rojo. — Rojo: Se requiere intervención, se deben realizar un análisis de causalidad para determinar las razones del incumplimiento y el bajo rendimiento. — Amarillo: se debe vigilar de cerca el indicador para detectar un posible deslizamiento de Rojo. — Verde: no se requiere ninguna acción.
Evidencia de implementación	Listas de participación de todos los entrenamientos de sensibilización; recuento de registros/registros con campo de entrenamiento SGSI/relleno de fila como “recibido”.
Frecuencia	Recopilación: Mensual, primer día hábil del mes. Análisis: Trimestral. Informe: Trimestral. Revisión de medición: Revisar anualmente. Periodo de medición: Anual.
Partes responsables	Propietario de la información: Gerente de formación – Recursos Humanos. Recopilador de información: Gestión de la formación - Departamento de recursos humanos. Cliente de medición: Gerentes responsables de un SGSI, director de seguridad de la información.
Fuentes de datos	Base de datos empleados, registros de capacitación, lista de participación de capacitaciones de concientización.

Formato de informe	Gráfico de barras, con barras codificadas por colores según el objetivo. Un breve resumen de lo que significa la medida y las posibles acciones de gestión deben adjuntarse al gráfico de barras o gráfico circular para la situación actual y gráfico lineal para la representación de la evolución del cumplimiento.
Relación	ISO/IEC 27001:2013, A.7.2: Competencia.

© ISO/IE - Todo Derechos Reservados

Este documento forma parte de la biblioteca de la UNIVERSIDAD INTERNACIONAL DE LA RIOJA



B.12 Capacitación en seguridad de la información

Descriptor de Información	Significado o propósito
ID de medida	Definido por la organización.
Necesidad de Información	Evaluar el cumplimiento del requisito anual de capacitación en concientización sobre seguridad de la información.
Medida	Porcentaje del personal que recibió capacitación anual en concientización sobre seguridad de la información.
Fórmula/puntuación	[Número de empleados que recibieron capacitación anual en concientización de seguridad de la información/Número de empleados que necesitan recibir capacitación anual en concientización de seguridad de la información] * 100.
Objetivo	0-60% - Rojo; 60-90% - Amarillo; 90-100% Verde. Para Amarillo, si no se logra un progreso de al menos el 10% por trimestre, la calificación es automáticamente roja. Rojo: se requiere intervención, se debe realizar un análisis de causalidad para determinar las razones del incumplimiento y el bajo rendimiento. Amarillo: el indicador debe vigilarse de cerca para detectar un posible deslizamiento a rojo. Verde: no se requiere ninguna acción.
Evidencia de Implementación	Recuento de registros/registros con campo de formación de conciencia de seguridad de información anual/relleno de fila como “recibido”.
Frecuencia	Recopilar: Mensualmente, primer día laborable del mes Análisis: Trimestral. Informe: Trimestral. Revisión de medición: Revisar anualmente. Periodo de medición: Anual.
Partes responsables	Propietario de la información: Oficial de seguridad de la información y Gerente de capacitación. Recopilación de información: Gestión de la capacitación – Departamento de recursos humanos. Cliente de medición: Gerentes responsables de un SGSI; gestión de seguridad; gestión de la información.

Fuente de datos	Base de datos de empleados, registros de entrenamiento.
Formato de Informe	Gráfico de barras con barras codificadas por colores según el objetivo. Un breve resumen de lo que significa la medida y las posibles acciones de gestión deben adjuntarse al gráfico de barras.
Relación	ISO/IEC 27001:2013, A.7.2.2: Concienciación sobre la seguridad de la información, educación y capacitación.

© ISO/IE - Todo Derechos Reservados

Este documento forma parte de la biblioteca de la UNIVERSIDAD INTERNACIONAL DE LA RIOJA

Descriptor de información	Significado o propósito
ID de medida	Definido por la organización
Necesidad de información	Evaluar el estado de cumplimiento de la política de conciencia de seguridad de la organización entre el personal relevante
Medida	1. Progreso hasta la fecha 2. Progreso hasta la fecha con la firma
Fórmula / puntuación	Obtenga el "progreso hasta la fecha" agregando el estado de todo el personal que ha firmado, planeado para completarse hasta la fecha Obtenga "progreso hasta la fecha con la firma" dividiendo el personal que ha firmado hasta la fecha por el personal planificado para la firma hasta la fecha a) [divida el progreso hasta la fecha entre (personal planificado hasta la fecha multiplicado por 100)] y avance hasta la fecha con la firma. b) Compare el estado con estados anteriores.
Objetivo	a) Las proporciones resultantes deberían caer respectivamente entre 0.9 y 1.1 y entre 0.99 y 1.01 para concluir el logro del objetivo de control y ninguna acción; y b) La tendencia debe ser al alza o estable.
Evidencia de implementación	1.1. Contar el número de personal programado para haber firmado y completado la capacitación hasta la fecha. 1.2. Pídale a la persona responsable el porcentaje de personal que ha completado la capacitación y firmado. 2.1. Contar el número de personal programado para haber firmado en esta fecha. 2.2. Contar el número de personal que ha firmado acuerdos de usuario.
Frecuencia	Recopilar: Mensualmente, primer día laborable del mes. Informe: Trimestral. Revisión de medición: Revisar anualmente. Período de medición: Anual
Partes responsables	Propietario de la información: oficial de seguridad de la información y gerente de capacitación. Recopilador de información: administración de la capacitación; Departamento de recursos humanos Cliente de medición: gerentes responsables de un SGSI; Gestión de seguridad. gestión de la información.